# 國 立 臺 北 商 業 大 學

## 資 訊 管 理 系

## １ １ ５ ’資 訊 系 統 專 案 設 計

# 系統手冊



**組　　別：第 115206 組**

**題　　目：RiskGenie 評評理**

**指導老師：徐國鈞老師**

**組　　長：11436017 顏珮倪**

**組　　員：11436008 林紀媗 11436010 李昕縈**

**11436021 黃翊甄 11436029 林敬芬**

**中 華 民 國 １ １ ５ 年 １ ０ 月 １ ４ 日**

# 目錄

**第 1 章 前言 ..... 1**

1-1 背景介紹 [序號 1] ..... 1

1-2 動機 ..... 1

1-3 系統目的與目標 ..... 2

1-4 預期成果 [序號 1] ..... 3

**第 2 章 營運計畫 ..... 5**

2-1 可行性分析 ..... 5

2-2 商業模式— Business model ..... 7

2-3 市場分析 — STP ..... 9

2-4 競爭力分析 SWOT-TOWS ..... 11

**第 3 章 系統架構 ..... 13**

3-1 系統架構 ..... 13

3-2 系統軟、硬體需求與技術平台 ..... 14

3-3 使用標準與工具 ..... 15

**第 4 章 專案時程與組織分工 ..... 18**

4-1 專案時程：甘特圖 ..... 18

4-2 專案組織與分工 ..... 18

4-3 上傳 GitHub 紀錄 ..... 21

**第 5 章 需求模型 ..... 22**

5-1 使用者需求 ..... 22

5-2 使用個案圖 ..... 24

5-3 活動圖 ..... 25

5-4 分析類別圖 ..... 38

**第 6 章 設計模型 ..... 39**

6-1 循序圖 ..... 39

6-2 設計類別圖 ..... 47

**第 7 章 實作模型 ..... 48**

7-1 佈署圖 ..... 48

7-2 套件圖 ..... 48

7-3 元件圖 ..... 49

7-4 狀態機圖與時序圖 ..... 50

**第 8 章 資料庫設計 ..... 51**

8-1 資料庫關聯表（參考關係與限制 Constraints） ..... 51

8-2 表格及其 Meta Data ..... 52

**第 9 章 程式 ..... 57**

9-1 元件清單及其規格描述 ..... 57

9-2 其他附屬之各種元件 ..... 58

**第 10 章 測試模型 ..... 76**

10-1 測試計畫 ..... 76

10-2 測試個案與測試結果資料 ..... 77

**第 11 章 操作手冊 ..... 79**

11-1 系統需求 ..... 79

11-2 系統連線與操作方式 ..... 79

**第 12 章 使用手冊 ..... 81**

**第 13 章 感想 ..... 85**

**第 14 章 參考資料 ..... 88**

**附錄 ..... 89**

# 圖目錄

圖 3-1-1 系統架構圖 ..... 14

圖 4-1-1 專案時程：甘特圖 ..... 18

圖 4-3-1 GitHub 紀錄 ..... 21

圖 5-2-1 使用個案圖 ..... 24

圖 5-3-1 活動圖－登入作業 ..... 25

圖 5-3-2 活動圖－新增資訊資產作業 ..... 26

圖 5-3-3 活動圖－刪除資訊資產作業 ..... 27

圖 5-3-4 活動圖－修改資訊資產作業 ..... 28

圖 5-3-5 活動圖－查詢資訊資產作業 ..... 29

圖 5-3-6 活動圖－資產盤點作業 ..... 30

圖 5-3-7 活動圖－風險評鑑作業 ..... 31

圖 5-3-8 活動圖－風險評鑑 AI 建議作業 ..... 32

圖 5-3-9 活動圖－風險報表產生作業 ..... 33

圖 5-3-10 活動圖－查詢帳號作業 ..... 34

圖 5-3-11 活動圖－新增帳號作業 ..... 35

圖 5-3-12 活動圖－修改/停用帳號作業 ..... 36

圖 5-3-13 活動圖－備份系統資料作業 ..... 37

圖 5-4-1 分析類別圖 ..... 38

圖 6-1-1 循序圖－登入作業 ..... 39

圖 6-1-2 循序圖－新增資訊資產作業 ..... 40

圖 6-1-3 循序圖－刪除資訊資產作業 ..... 40

圖 6-1-4 循序圖－修改資訊資產作業 ..... 41

圖 6-1-5 循序圖－查詢資訊資產作業 ..... 41

圖 6-1-6 循序圖－資產盤點與 AI 建議作業 ..... 42

圖 6-1-7 循序圖－風險評鑑作業 ..... 43

圖 6-1-8 循序圖－風險評鑑 AI 建議作業 ..... 44

圖 6-1-9 循序圖－風險報表產生作業 ..... 44

圖 6-1-10 循序圖－查詢帳號作業 ..... 45

圖 6-1-11 循序圖－新增帳號作業 ..... 45

圖 6-1-12 循序圖－修改/停用帳號作業 ..... 45

圖 6-1-13 循序圖－備份系統資料作業 ..... 46

圖 6-2-1 設計類別圖 ..... 47

圖 7-1-1 佈署圖 ..... 48

圖 7-2-1 前端套件圖 ..... 48

圖 7-2-2 後端套件圖 ..... 48

圖 7-3-1 元件圖 ..... 49

圖 7-4-1 狀態機圖 ..... 50

圖 7-4-2 時序圖 ..... 50

圖 8-1-1 資料庫關聯表 ..... 51

# 表目錄

表 2-2-1 商業模式 ..... 7

表 2-2-2 學生專題階段－成本的量化估算 ..... 7

表 2-2-3 商業化階段－成本的量化估算 ..... 8

表 2-2-4 商業化階段－收益的量化估算 ..... 8

表 2-3-1 市場區隔 ..... 9

表 2-4-1 SWOT 分析 ..... 11

表 2-4-2 TOWS 分析 ..... 11

表 2-4-3 相關系統比較 ..... 12

表 3-2-1 系統軟體需求 ..... 15

表 3-2-2 系統硬體需求 ..... 15

表 3-3-1 系統開發環境與工具 ..... 17

表 4-2-1 專案組織與分工 ..... 18

表 4-2-2 專題成果工作內容與貢獻度表 ..... 20

表 5-1-1 功能需求清單 ..... 22

表 5-1-2 非功能需求清單 ..... 23

表 8-2-1 assets (資產表) 欄位定義 ..... 52

表 8-2-2 audit_logs (稽核紀錄表) 欄位定義 ..... 53

表 8-2-3 companies (公司表) 欄位定義 ..... 53

表 8-2-4 cve_documents (CVE 漏洞文件資料表) 欄位定義 ..... 53

表 8-2-5 cve_embeddings (CVE 漏洞向量資料表) 欄位定義 ..... 54

表 8-2-6 cve_sync_runs (CVE 同步紀錄表) 欄位定義 ..... 54
表 8-2-7 departments (部門表) 欄位定義 ..... 55
表 8-2-8 risk_assessments (AI 風險分析結果表) 欄位定義 ..... 55
表 8-2-9 roles (角色表) 欄位定義 ..... 55
表 8-2-10 users (使用者表) 欄位定義 ..... 56
表 8-2-11 vulnerabilities (弱點表) 欄位定義 ..... 56
表 8-2-12 weight_settings (風險權重設定資料表) 欄位定義 ..... 56
表 9-1-1 前端程式清單 ..... 57
表 9-1-2 後端程式清單 ..... 57
表 9-2-1 相關套件清單 ..... 58
表 9-2-2 部分程式碼－asset_service.py ..... 58
表 9-2-3 部分程式碼－backup_service.py ..... 60
表 9-2-4 部分程式碼－rag_service.py ..... 62
表 9-2-5 部分程式碼－risk_service.py ..... 71
表 10-1-1 測試項目表 ..... 76
表 10-2-1 登入功能測試結果 ..... 77
表 10-2-2 資訊資產 CRUD 功能測試結果 ..... 77
表 10-2-3 資產盤點功能測試結果 ..... 77
表 10-2-4 風險評鑑功能測試結果 ..... 78
表 10-2-5 風險評鑑 AI 建議功能測試結果 ..... 78
表 10-2-6 權重設定功能測試結果 ..... 78

表 10-2-7 帳號與權限管理測試結果 ..... 78
表 10-2-8 系統資料備份測試結果 ..... 78
表 11-1-1 系統安裝元件與環境設定 ..... 79
表 11-1-2 系統管理功能 ..... 79
表 12-1-1 登入作業 ..... 81
表 12-1-2 主畫面 ..... 81
表 12-1-3 資產總表 ..... 82
表 12-1-4 資產盤點 ..... 82
表 12-1-5 風險評鑑 ..... 83
表 12-1-6 風險評鑑 AI 建議 ..... 83
表 12-1-7 風險報表 ..... 84
表 12-1-8 權重設定 ..... 84

# 第 1 章 前言

## 1-1 背景介紹 [序號 1]

隨著全球數位化與雲端服務的普及，資訊安全已成為組織營運不可或缺的一部分。為建立具備國際公信力的資安防護體系，許多組織選擇導入 ISO 27001 資訊安全管理系統（ISMS）。在 ISMS 的標準維運 PDCA 流程中，「資產盤點」與「風險評鑑」是決定資安政策成敗的關鍵前期作業。

然而，現行的實務運作高度依賴人工填寫與主觀判斷。組織內的資安承辦人員通常需要面對成百上千筆的 Excel 資產表格，逐一填寫各項資產的機密性（C）、完整性（I）、可用性（A）分級。由於缺乏客觀的參照標準，不同的承辦人員常因個人經驗差異，可能無法對於相同資產給出客觀的評價。

此外，面對日新月異的資安威脅與新興漏洞，人工方式導致風險評鑑往往淪為應付稽核的靜態文書作業，難以反映現實中動態的威脅環境。

## 1-2 動機

本專題之研發動機，源於發現組織在執行 ISMS 風險評鑑時，企業所面臨的實務痛點：

（一）資安承辦人員的標準不一的問題：

承辦人員在面對跨部門匯入的原始 Excel 資產盤點表時，難以在短時間內核對資產分類的正確性，無法憑一己之力了解所有硬體設備或軟體版本的已知漏洞。這導致弱點與威脅值的評估會主觀的憑感覺填寫。

（二）資安主管的決策困境：

由於傳統評鑑可能導致風險分數失真，主管無法精確掌握真正面臨的「關鍵風險項目」，造成資安預算與人力資源的錯配。

（三）隱私外洩與 AI 幻覺：

雖然引進大型語言模型能輔助分析，但資安資料極度敏感。若將包含組織名稱、內部 IP 等機敏資料直接上傳雲端 AI，將引發嚴重的資安外洩危機；且 AI 的「幻覺現象」可能產出錯誤的資安法規與對策建議，這在講求精確合規的資安稽核中是不被允許的。

因此，如何建構一套專注於資安面向、具備隱私防護機制，並能動態串接外部漏洞情資與 ISO 標準規範的智慧化顧問系統，成為本組的研究重點。

## 1-3 系統目的與目標

本專題旨在開發一套名為「RiskGenie 評評理」的支援 ISMS 運作之 AI 風險顧問系統。透過將「生成式 AI」與「合規規則引擎」深度結合，協助組織將原先繁瑣且主觀的人工作業，轉化為數據驅動的標準合規流程。

系統具備四大具體目標：

1. 建立利害關係人導向的智慧盤點功能： 支援批次匯入組織既有的 Excel 資產表，由 AI 進行欄位對齊與語意分析，客觀給予資產分類與 CIA 價值建議，並自動生成分級理由以供外部稽核員查核。

2. 實作數據驅動與彈性公式的動態風險評鑑： 定期更新 NVD/CVE 漏洞情資至本地資料庫，將外部真實的漏洞 CVSS 分數引入系統。系統透過排程機制自動更新本地漏洞快取，確保風險評鑑在無需即時連線外部服務的情況下，仍能取得準確的漏洞數據進行計算。同時，系統架構預留公式彈性，能兼容不同組織自定義的風險計算需求。

3. 建構機敏資料去識別化防護層： 在資料傳輸至雲端模型前，系統將自動進行隱私過濾，遮蔽具備辨識性的機構名稱與關鍵參數，在完全保障資安隱私的前提下發揮 AI 的分析效益。

4. 建置基於 RAG 技術的合規方式： 透過檢索增強生成技術，強制 AI 依據 ISO 27002:2022 的標準控制措施知識庫進行建議生成，降低 AI 產生錯誤資訊的風險，自動產出具備高度精確性與實作價值的資安改善 SOP 草案。

## 1-4 預期成果 [序號 1]

本系統預期在實務與管理層面達成以下成果：

1. 大幅提升資安行政效率： 將原本需耗時數週的資產比對與漏洞查詢工作，縮短至數分鐘內批次完成，降低資安承辦人員的行政負擔。

2. 落實「人機協同」與差異分析透明化： 系統將清晰呈現「原始資料」與「AI 建議」的差異。系統定位為「顧問」，最終決策權仍保留給人工審核，並詳實記錄人工檢驗與修正的軌跡，確保決策的正確性與可追溯性。

3. 優化組織資安資源分配： 透過修正後的最大風險演算法，為資安主管產出準確

的風險熱力圖與高風險分佈報告，使組織能將有限的資源精準投注在最脆弱的防護破口上。

4. 提供安全、合規且具公信力的資安文件： 在確保機敏資料不外洩的安全框架下，產出符合國際標準的風險處理計畫書與標準作業程序（SOP），輔助組織順利通過 ISO 27001 稽核。

# 第 2 章 營運計畫

## 2-1 可行性分析

1. 市場需求分析：

台灣已通過 ISO 27001 驗證的組織約以千為單位,加上預備導入、教育部資通安全等級要求的學校，以及金管會逐年加嚴的金融業要求，ISMS 文書負擔的問題本身存在，但中大型企業已被 E-SOFT、Secorion 等既有合規平台覆蓋。我們不是與它們正面對撞，而是讓「買不起合規平台又必須做 ISMS」的中小企業、學校有多一種選擇。

2. 技術可行性分析：

- 系統功能可透過一般 Web 架構實作：

  本系統功能包含登入、資訊資產新增、刪除、修改、查詢、資產盤點檢查、風險評鑑、AI 改善建議、風險報表、帳號權限管理及資料備份等，皆可透過前端介面、後端程式、資料庫與 API 串接完成。

- 開發技術具備可取得性：

  系統可採用 Python 作為後端開發語言，並搭配資料庫儲存資產資料、風險評估結果與使用者資料。

- AI 功能可透過外部 API 輔助完成：

  AI 改善建議可串接外部 AI 模型 API 產生初步建議，再由使用者進行確認與修正，不需自行訓練大型 AI 模型。

- 需注意技術風險：

  系統仍需注意 AI 回答正確性、資料安全性、伺服器穩定性與後續維護成本。

3. 風險與挑戰：

- 團隊可依功能模組分工：

  團隊可依系統功能進行分工，例如資產管理模組、風險評鑑模組、AI 建議模組、報表模組與帳號權限模組，降低開發與管理負擔。

- 未來可採訂閱制模式發展：

  若未來朝商業化發展，系統可採用 SaaS 訂閱制，讓使用單位依每月或每年方式付費使用。

- 功能可分階段擴充：

  初期可提供資產盤點、風險評鑑與 AI 改善建議等基本功能；後續再加入多部門管理、權限控管、報表匯出與外部情資串接等進階功能。

- 營運風險可逐步控管：

  由於本系統初期以專題展示為主，可先降低伺服器、客服與商業推廣成本，待系統成熟後再評估正式營運需求。

## 2-2 商業模式— Business model

表 2-2-1 商業模式 [序號 2]

<table>
<tr>
<td rowspan="2">關鍵合作夥伴<br>・AI 模型供應商、雲端服務供應商、ISMS 顧問公司</td>
<td>關鍵活動<br>・平台開發和維護<br>・資安知識庫更新<br>・用戶支持與客戶服務<br>・市場營銷和推廣</td>
<td rowspan="2">價值主張<br>・降低資安風險成本<br>・即時、高效的追蹤風險<br>・降低資安風險評鑑門檻<br>・提供 AI 白話化改善建議</td>
<td>顧客關係<br>・定期更新<br>・用戶互動</td>
<td rowspan="2">目標客群<br>・所有導入 ISMS 的企業</td>
</tr>
<tr>
<td>關鍵資源<br>・開發團隊<br>・伺服器和技術基礎設施<br>・市場推廣資源<br>・資安知識內容</td>
<td>通路<br>・線上平台<br>・顧問公司推薦</td>
</tr>
<tr>
<td colspan="3">成本結構<br>・伺服器與資料庫成本<br>・系統開發與維護成本<br>・AI API 使用成本<br>・行銷推廣成本</td>
<td colspan="2">收益流<br>・訂閱制收入<br>・顧問合作分潤<br>・企業版授權</td>
</tr>
</table>

表 2-2-2 學生專題階段－成本的量化估算

| 成本項目 | 估算依據 | 金額 |
|---|---|---|
| 開發人力(機會成本) | 5 人 × 80 小時 × NT$200 / 小時 | NT$80,000(一次性) |
| 雲端資料庫 | Supabase Free Tier(500 MB) | NT$0 / 月 |
| AI API 測試用量 | Gemini API 免費額度加少量付費 | NT$300 / 月 |
| 其他工具與部署 | 網域、測試環境 | NT$500 / 月 |
| 小計 | | 一次性 NT$80,000<br>+ NT$800<br>=NT$80,800 / 月 |

表 2-2-2 成本的量化估算說明：在學階段沒有實際付薪資，但為符合系統企劃成本估算邏輯，以工讀時薪 NT$200 估機會成本。

表 2-2-3 商業化階段－成本的量化估算

| 成本項目 | 估算依據 | 估算金額 |
|---|---|---|
| 系統維護人力 | 1 名兼職工程師或維護人員 | NT$60,000／月 |
| 雲端伺服器與資料庫 | 伺服器、資料庫、備份與流量費用 | NT$5,000／月 |
| AI API 使用費 | 依使用者查詢與改善建議產生次數估算 | NT$10,000／月 |
| 系統維護與資安防護 | 系統更新、弱點修補、權限與備份維護 | NT$10,000／月 |
| 行銷推廣成本 | 線上推廣、簡介製作與合作推廣 | NT$15,000／月 |
| 小計 | | NT$100,000／月 |

2-2-4 商業化階段－收益的量化估算

| 收益項目 | 假設條件 | 估算金額 |
|---|---|---|
| 訂閱制收入 | 500 單位 × NT$500／月 | NT$250,000／月 |
| 企業版或進階功能收入 | 進階報表、權限管理或客製化功能 | NT$20,000／月 |
| 合作夥伴收入 | 顧問公司推薦或合作推廣 | NT$20,000／月 |
| 小計 | | NT$290,000／月 |

## 2-3 市場分析 — STP

### 一、市場區隔(Segmentation)

我們從組織規模、產業屬性、ISMS 導入階段三個軸切市場，如表 2-3-1 市場區隔所示。

表 2-3-1 市場區隔

| 軸線 | 區隔 | 特性 | 對 RiskGenie 的需求度 |
|---|---|---|---|
| 組織規模 | 中小企業 | 資安人力 0–1 人,常委外 | 高 |
| | 中大型企業 | 已有內部團隊或既有合規平台 | 中(切入難度高) |
| | 顧問公司 | 同時服務多家客戶 | 中(可作為通路) |
| 產業屬性 | 學校 | 預算受限,合規壓力來自上級機關 | 高 |
| | 科技與製造 | 資產量大、供應鏈合規要求 | 中 |
| | 金融與醫療 | 法規最嚴,但既有平台覆蓋深 | 低 |
| ISMS 導入階段 | 預備導入 | 缺範本與流程引導 | 高 |
| | 導入中 | 正在整理資產與評鑑 | 高 |
| | 已導入 | 例行維護與報表 | 中 |

### 二、目標市場(Targeting)

初期鎖定：預備導入或導入中的學校單位與中小企業。 理由：

1. 資安人力薄弱,工具替代人力的價值最直接;

2. 預算敏感,既有合規平台對他們太貴,我們有價格空間;

3. 資產規模可控(數百至數千筆)。

中長期擴張：資安顧問公司(作為通路放大器,而非直接客戶)、以及中大型企業的進階版需求。金融與醫療因法規門檻與信任建立成本過高，本專題期程內不主動切入。

三、產品定位(Positioning)

本系統不是完整取代資安顧問，也不是大型企業使用的完整合規管理平台，而是提供一套較低門檻、較容易操作的輔助工具。其定位重點如下：

1. 低門檻：以簡單介面協助使用者完成資料填寫與查詢。
2. 高效率：減少人工盤點與填寫風險評估表的時間。
3. 可理解：AI 將資安建議轉換為較白話的改善方向。
4. 保留人工判斷：AI 僅提供建議，最終結果仍由使用者確認。

## 2-4 競爭力分析 SWOT-TOWS

表 2-4-1 SWOT 分析

| 優勢 S | 劣勢 W |
|---|---|
| 1. 「AI 給建議、規則算分、RAG 給來源」三層架構,風險分數可解釋、可重算、可審計<br>2. 保留人工值、另存 AI 建議與 cia_delta,差異分析透明<br>3. CIA 權重可由使用者調整<br>4. 鎖定 ISO 27002:2022,對齊現行國際標準 | 1. 多租戶、權限控管、情資快取等商業化要件未完成<br>2. 依賴 Gemini 單一 LLM 供應商<br>3. 知識庫須隨 ISO 標準更新人工維護 |
| **機會 O** | **威脅 T** |
| 1. 教育部資通安全等級要求逐年加嚴,學校單位需求升溫<br>2. 中小企業 ISMS 導入意願提升,但缺工具<br>3. 生成式 AI 應用接受度普及,組織願意嘗試<br>4. 顧問公司可能採用本系統提升輔導效率 | 1. E-SOFT、Secorion 等合規平台已具品牌與客戶基礎<br>2. 資安資料敏感,雲端 AI 工具信任建立慢<br>3. ISO 標準與法規變動,需持續維護成本<br>4. AI 建議錯誤可能導致使用者信任流失 |

表 2-4-2 TOWS 分析

| | 優勢 S | 劣勢 W |
|---|---|---|
| 機會 O | 以三層架構的可解釋性切入學校與中小企業,主打「比 Excel 快、比顧問便宜、比合規平台輕」 | 學生階段不打多租戶,但用 PoC 在學校單位累積案例,後續再投入企業級功能 |
| 威脅 T | 以「規則引擎算分、AI 不直接決定分數」回應對 AI 信任的疑慮;以條文引用回應 AI 幻覺風險 | 不過度宣稱商業成熟度,定位明確為輔助工具與 PoC,避免與企業級平台直接競爭 |

表 2-4-3 相關系統比較之評比依據：依各系統公開官網與導入文件(2026/04 查詢)整理。

表 2-4-3 相關系統比較

| 比較項目 | RiskGenie 評評理 | E-SOFT | Secorion 資安合規 |
|---|---|---|---|
| 主要定位 | AI 輔助 ISMS 風險評鑑 | 企業資安管理 | 資安合規管理 |
| 目標客群 | 學校、中小企業、ISMS 初期 | 中大型企業 | 中大型企業 |
| 使用門檻 | 低(下拉選單與匯入) | 中高(需設定) | 中高(需顧問導入) |
| AI 輔助 | 三層架構,引用條文 | 較低或客製化 | 較低 |
| 風險評鑑效率 | 高(自動計算與建議) | 中 | 中 |
| 報表能力 | 風險報表與高風險清單 | 完整管理報表 | 完整合規報表 |
| 導入成本 | 低 | 高 | 高 |
| 多租戶 | 不具備(規劃中) | 已具備 | 已具備 |

差異化重點：RiskGenie 不與企業級平台正面競爭,而是補上「人力不足做不了風險評鑑」這塊既有平台不服務的市場。

# 第 3 章 系統架構

## 3-1 系統架構

本系統旨在輔助使用者進行資訊資產盤點與風險評鑑，降低傳統人工評鑑所需的時間與專業門檻，並提升整體資安管理效率。透過使用者輸入資產資料，結合生成式人工智慧（Gemini）與檢索增強生成技術（RAG）進行分析，自動產出風險評鑑結果與建議措施，以提供使用者作為決策參考。系統架構主要分為三個部分：

1. 前端介面：使用 HTML、CSS 與 JavaScript 建構操作介面，提供使用者直覺化的操作環境。使用者可透過網頁進行資產盤點、風險評鑑與結果查詢，提升操作便利性與使用體驗。
2. 後端服務：採用 Python Flask 框架進行開發，負責系統核心邏輯、資料處理、RESTful API 服務建置，以及 Gemini 模型串接功能。系統導入 RAG 技術，透過定期蒐集與更新公開漏洞資料（CVE）至本地知識庫，作為風險分析之參考依據。當使用者執行資產盤點或風險評鑑時，系統會先檢索知識庫中與資產相關之漏洞資訊，再結合使用者輸入資料提供給 Gemini 模型進行分析與建議生成，以提升評鑑結果之準確性與即時性。
3. 資料庫與系統整合：使用 Supabase 雲端資料庫（PostgreSQL）進行資料儲存與管理，負責保存使用者資料、資訊資產清單、風險評估結果及 CVE 漏洞知識庫資料。系統透過排程機制定期同步最新 CVE 資訊，以確保風險評鑑所依據之資安資料具備時效性。

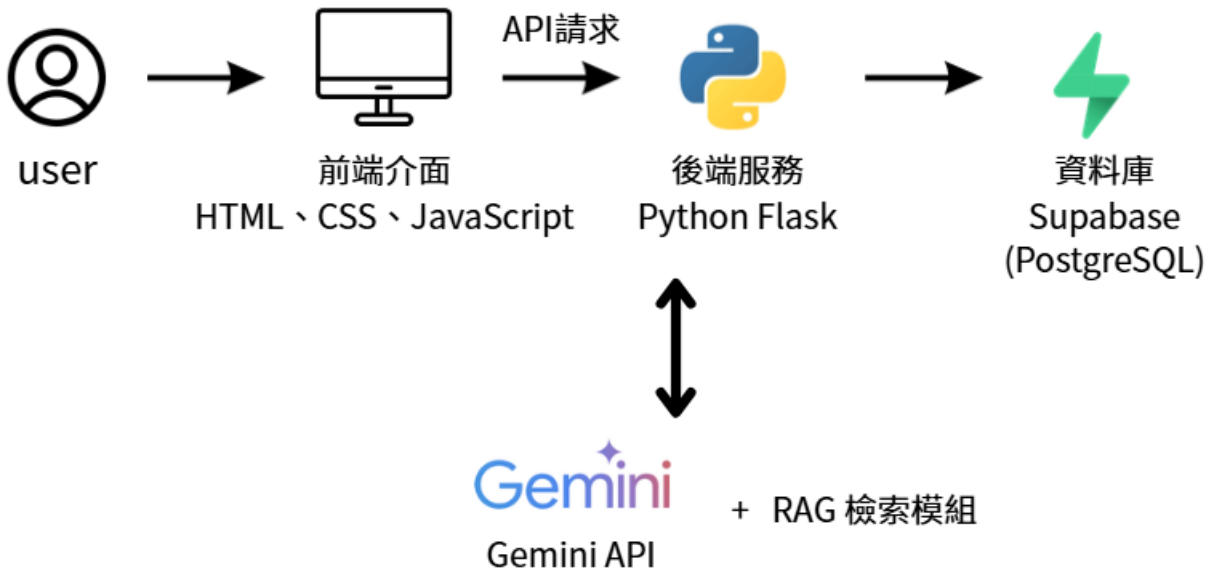



圖 3-1-1 系統架構圖

圖 3-1-1 顯示本系統之整體架構。本系統採用前後端分離架構，使用者透過前端介面發送 API 請求，由後端 Flask 伺服器協調資訊資產管理、風險評鑑及 AI 資安改善建議等模組進行處理。在產生 AI 資安改善建議時，系統透過 RAG（檢索增強生成）機制，檢索相關資安知識，並將檢索結果與使用者提供的風險評鑑資訊一併傳送至 Gemini API，產生具備資安知識參考依據的改善建議，供使用者審核與確認。

## 3-2 系統軟、硬體需求與技術平台

本系統採用現代化網頁技術架構，以 HTML、CSS 與 JavaScript 建構前端介面，並結合 Python Flask 後端框架與 Supabase 雲端資料庫，建置一套完整的資安風險評估平台。考量現今使用者多透過不同裝置進行操作，本系統設計為跨平台網頁應用，支援電腦與行動裝置瀏覽器，使用者可隨時進行資產盤點與風險評鑑。此外，由於採用 Supabase 作為雲端資料庫服務，可降低傳統資料庫伺服器建置與維護成本，並提升資料同步、備份與存取之便利性。系統軟、硬體需求如下：

表 3-2-1 系統軟體需求

| 項目 | 需求規格說明 |
|---|---|
| 作業系統 | Windows / macOS / Linux |
| 前端技術 | HTML、CSS、JavaScript |
| 後端技術 | Python Flask |
| 資料庫 | Supabase（PostgreSQL 雲端資料庫） |
| API 設計 | RESTful API |
| 技術與模型 | RAG、Gemini |
| 開發工具 | Visual Studio Code |
| 版本控制 | GitHub |
| 瀏覽器 | Chrome、Edge、Safari |

表 3-2-2 系統硬體需求

| 項目 | 需求規格說明 |
|---|---|
| 裝置類型 | 支援瀏覽器之電腦、手機或平板 |
| 作業系統 | Windows 10 以上 / macOS / Android / iOS |
| 記憶體 | 建議 4GB 以上 |
| 網路需求 | 穩定網際網路連線 |
| 儲存空間 | 至少 50MB（用於暫存資料） |

## 3-3 使用標準與工具

以下列出本系統於開發「RiskGenie 評評理」時所使用之主要開發工具與技術，並說明其特點與選用理由：

1. 開發工具與技術說明： [序號 3]

- Python：具備語法簡潔、可讀性高與開發效率佳等特性，並擁有豐富的第三方套件資源，適合用於後端開發與資料處理。本系統採用 Python 作為主要後端開發語言，以提升系統開發效率與維護性。
- Flask：為 Python 的輕量級 Web 框架，具備高彈性與擴充性。本系統透過 Flask 實作後端服務，處理資產資料、風險評估邏輯與使用者管理功能。

- Supabase：為基於 PostgreSQL 之雲端資料庫平台，提供資料儲存與 API 整合功能。本系統用於儲存使用者資料、資產清單與風險評估結果，以提升資料管理效率與系統擴充性。
- HTML / CSS / JavaScript：作為前端開發之標準技術，負責使用者介面呈現與互動功能實作，並支援多裝置瀏覽，提升使用者體驗。
- Gemini 生成式人工智慧模型：用於風險分析與建議生成，以提升分析效率與決策品質，並於資料傳送前進行敏感資訊去識別化處理，以降低敏感資料外洩風險並提升資料安全性。
- RAG 檢索增強生成技術：透過檢索增強生成（RAG）技術，從本地資安知識庫中擷取與使用者資產相關之資訊，並將檢索結果作為 Gemini 模型之額外上下文資訊，以提升分析準確性。該知識庫內容包含定期更新之 CVE 漏洞資料與相關資安規範，使系統能反映最新資安威脅情境。透過結合檢索資料與生成式 AI 分析，可降低模型產生錯誤資訊之風險，並提升風險評鑑結果與改善建議之可信度與即時性。
- Visual Studio Code：為輕量且功能完整之開發工具，支援多種程式語言與除錯功能，並可透過擴充套件提升開發效率，是本系統主要開發環境。
- GitHub：用於版本控制與專案管理，支援多人協作開發、版本追蹤與程式碼備份，有助於提升團隊開發效率與程式品質。

2. 軟體工程標準： [序號 3]

- UML：用於系統分析與設計，包含系統架構圖、循序圖與類別圖等，以提升系統設計之完整性與可讀性。
- RESTful API 設計原則：作為前後端資料傳輸之設計依據，使系統架構清晰，並提升系統之擴展性與維護性。

表 3-3-1 系統開發環境與工具

| 系統開發環境 | |
|---|---|
| 作業系統 | Windows 11 |
| 開發平台 | HTML、JavaScript、Python、Flask、Supabase |
| 程式撰寫工具 | Visual Studio Code |
| 程式開發工具 | |
| 前端技術 | HTML、CSS、JavaScript |
| 後端技術 | Python、Flask、Supabase（PostgreSQL） |
| API 設計 | RESTful API |
| 技術與模型 | RAG、Gemini |
| 文件美工工具 | |
| 圖表設計 | Visual Paradigm Online |
| 文件 | Microsoft Word |
| 簡報 | Microsoft PowerPoint、Canva |
| 專案管理平台 | |
| 版本與專案管理 | GitHub |
| 檔案儲存 | GitHub、OneDrive |

# 第 4 章 專案時程與組織分工

## 4-1 專案時程：甘特圖

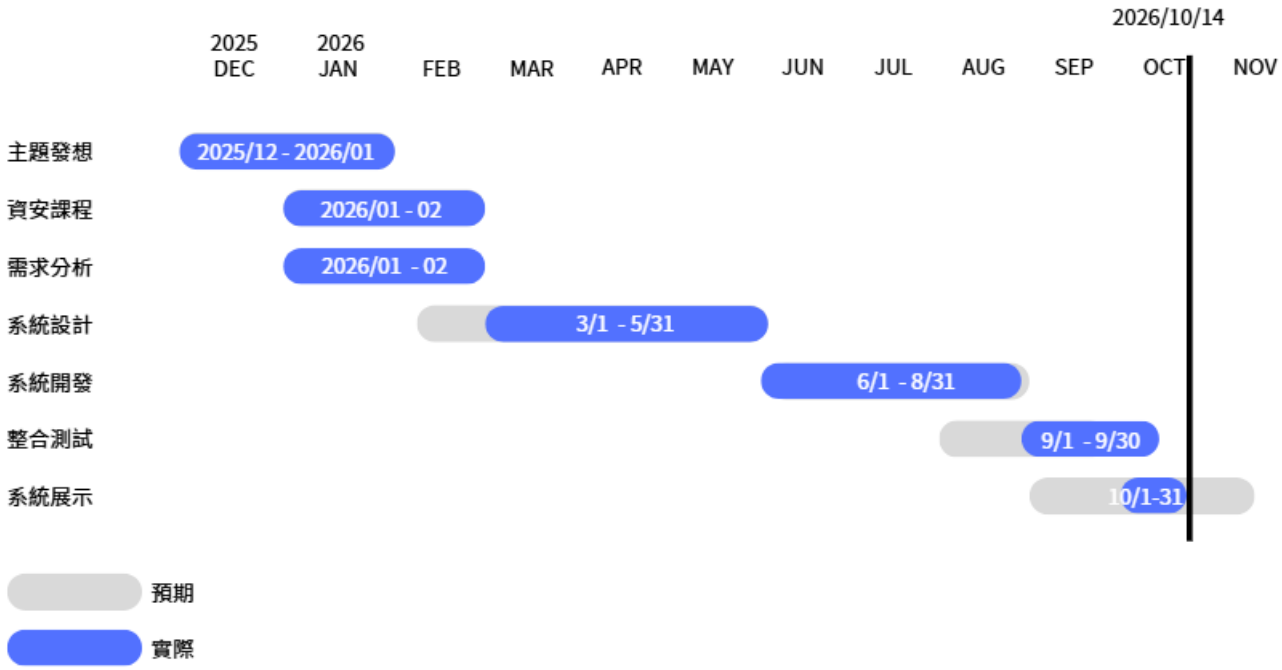



圖 4-1-1 專案時程：甘特圖

## 4-2 專案組織與分工

本專題由五位組員共同完成，依系統功能、文件撰寫及成果展示需求進行工作分配。符號說明：●主要負責人　○次要負責人

表 4-2-1 專案組織與分工

| 項目/組員 | | 11436008<br>林紀媗 | 11436010<br>李昕縈 | 11436017<br>顏珮倪 | 11436021<br>黃翊甄 | 11436029<br>林敬芬 |
|---|---|---|---|---|---|---|
| 後端開發 | 資料庫建置 | ● | | | ○ | |
| | 伺服器架設 | | | | | ● |
| | 1. 登入作業 | | | ● | | |
| | 2. 新增資訊資產作業 | ● | | | | |
| | 3. 刪除資訊資產作業 | ● | | | | |
| | 4. 修改資訊資產作業 | ● | | | | |
| | 5. 查詢資訊資產作業 | ● | | | | |
| | 6. 資產盤點作業 | ● | | | | |

| | | | | | | |
|---|---|---|---|---|---|---|
| | 7. 風險評鑑作業 | | | | | ● |
| | 8. 風險評鑑 AI 建議 | | ● | | | |
| | 9. 風險報表產生作業 | | ● | | | |
| | 10. 帳號與權限管理作業 | | | ● | | |
| | 11. 備份系統資料作業 | | | ● | | |
| 前端開發 | 1. 登入作業 | | | ● | | |
| | 2. 新增資訊資產作業 | | | | ● | |
| | 3. 刪除資訊資產作業 | | | | ● | |
| | 4. 修改資訊資產作業 | | | | ● | |
| | 5. 查詢資訊資產作業 | | | | ● | |
| | 6. 資產盤點作業 | | | | ● | |
| | 7. 風險評鑑作業 | | | | ● | |
| | 8. 風險評鑑 AI 建議 | | | | ● | |
| | 9. 風險報表產生作業 | | | ● | | |
| | 10. 帳號與權限管理作業 | | | ● | | |
| | 11. 備份系統資料作業 | | | | | |
| 美術設計 | UI/ UX | | | | ● | |
| | Web/APP 介面設計 | | | | ● | |
| | 色彩設計 | | | | ● | |
| | Logo 設計 | | | | | ● |
| | 素材設計 | | | | ● | |
| 文件撰寫 | 統整 | | ● | | | |
| | 第 1 章 前言 | | | | | ● |
| | 第 2 章 營運計畫 | | | ○ | ● | |
| | 第 3 章 系統規格 | | ● | | | |
| | 第 4 章 專題時程與組織分工 | | ○ | ● | | |
| | 第 5 章 需求模型 | | | ● | ○ | |
| | 第 6 章 設計模型 | | ● | | | |
| | 第 7 章 實作模型 | ● | | | | ○ |
| | 第 8 章 資料庫設計 | ● | | | | |
| | 第 9 章 程式 | | ● | | ○ | |
| | 第 10 章 測試模型 | | ● | | ○ | |
| | 第 11 章 操作手冊 | | ● | | ○ | |
| | 第 12 章 使用手冊 | | ● | | ○ | |
| 報告 | 簡報製作 | | ○ | | ● | |

表 4-2-2 專題成果工作內容與貢獻度表

| 序號 | 姓名 | 工作內容<各限 100 字以內> | 貢獻度 |
|---|---|---|---|
| 1 | 組長<br>11436017<br>顏珮倪 | ● 前端：登入作業、帳號與權限管理作業、備份系統資料作業<br>● 後端：登入作業、帳號與權限管理作業、備份系統資料作業<br>● 文件：第 4 章、5-1、5-2<br>● 競賽投稿 | 20% |
| 2 | 組員<br>11436008<br>林紀媗 | ● 資料庫建置<br>● 後端：新增資訊資產作業、刪除資訊資產作業、修改資訊資產作業、查詢資訊資產作業、資產盤點作業<br>● 文件：7-1、7-2、第 8 章 | 20% |
| 3 | 組員<br>11436010<br>李昕縈 | ● 後端：風險評鑑 AI 建議、風險報表產生作業<br>● 文件：第 3 章、第 6 章、第 9 章、第 10 章、第 11 章、第 12 章 | 19% |
| 4 | 組員<br>11436021<br>黃翊甄 | ● 資料庫建置<br>● 前端：新增資訊資產作業、刪除資訊資產作業、修改資訊資產作業、查詢資訊資產作業、資產盤點作業、風險評鑑作業、風險評鑑 AI 建議、風險報表產生作業<br>● 文件：第 2 章、5-3、5-4、第 9 章、第 10 章、第 11 章、第 12 章 | 22% |
| 5 | 組員<br>11436029<br>林敬芬 | ● 系統部署<br>● 後端：風險評鑑作業<br>● 文件：第 1 章、7-3、7-4 | 19% |
| | | | 總計:100% |

# 4-3 上傳 GitHub 紀錄

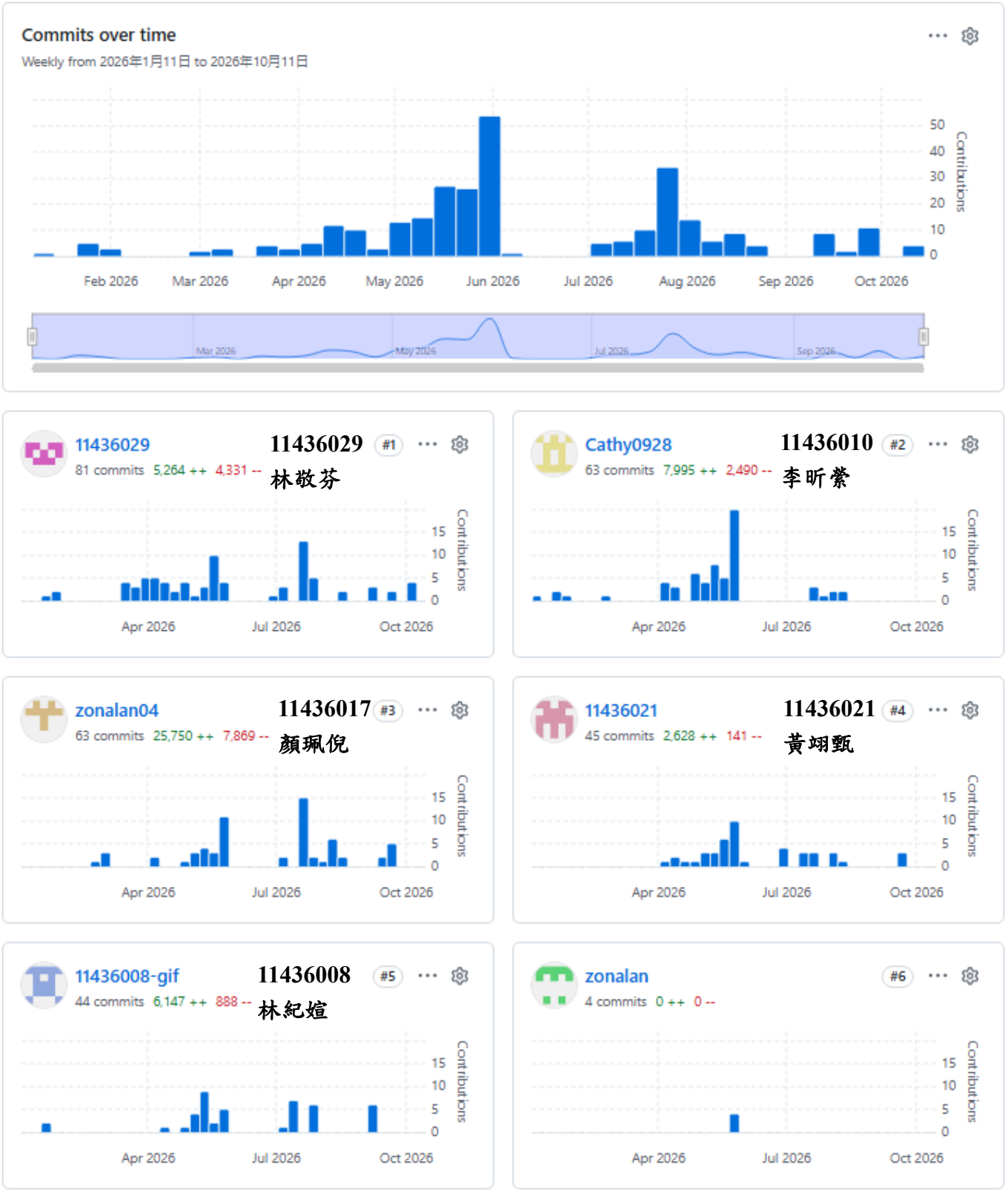



圖 4-3-1 GitHub 紀錄

# 第 5 章 需求模型

本章依據系統利害關係人目標與主要作業流程，整理 RiskGenie 評評理之功能需求、非功能需求與使用個案模型。本系統使用者包含一般使用者、資安管理員／高階主管及系統管理員；各項需求以資訊資產盤點、風險評鑑與 AI 改善建議為核心。

## 5-1 使用者需求

- 功能需求

表 5-1-1 功能需求清單 [序號 4]

| 編號 | 功能需求名稱 | 需求說明 | 使用者角色 |
|---|---|---|---|
| FR-01 | 登入作業 | 提供帳號密碼登入功能，並依使用者角色導向可使用之功能。 | 所有角色 |
| FR-02 | 資訊資產新增作業 | 提供新增資訊資產功能，輸入資產名稱、類別、負責人、用途及 CIA 等必要資料。 | 一般使用者 |
| FR-03 | 資訊資產刪除作業 | 提供刪除不再使用或誤建立之資訊資產資料功能。 | 一般使用者 |
| FR-04 | 資訊資產修改作業 | 提供修改既有資訊資產資料功能，以維持資產盤點資訊之正確性。 | 一般使用者 |
| FR-05 | 資訊資產查詢作業 | 提供依資產名稱、類別、負責人等條件查詢資訊資產資料。 | 一般使用者 |
| FR-06 | 資產盤點作業 | 檢查資訊資產資料之完整性，提示缺漏資料供使用者確認。 | 一般使用者 |
| FR-07 | 風險評鑑作業 | 依據資產價值、威脅及弱點等資訊進行風險評估，計算風險值並判定風險等級。 | 一般使用者 |
| FR-08 | 風險評鑑 AI 建議作業 | 結合風險評鑑結果及相關漏洞資訊，透過生成式 AI 產生風險改善建議，供使用者參考。 | 一般使用者 |
| FR-09 | 風險報表產生作業 | 提供整體風險報表，協助掌握優先處理項目。 | 資安管理員/高階主管 |
| FR-10 | 帳號與權限管理作業 | 提供帳號新增、修改及停用功能，並設定不同角色之系統使用權限。 | 系統管理員 |
| FR-11 | 備份系統資料作業 | 提供系統資料備份功能，以降低系統資料遺失之風險。 | 系統管理員 |

- 非功能需求

表 5-1-2 非功能需求清單 [序號 4]

| 編號 | 非功能需求名稱 | 需求說明 |
|---|---|---|
| NFR-01 | 安全性與權限控管 | 系統應透過登入驗證與角色權限限制功能存取，避免未授權操作。 |
| NFR-02 | 易用性 | 介面應清楚易操作，使使用者可完成資產盤點、風險評鑑與建議查看。 |
| NFR-03 | 可靠性 | 系統應穩定儲存與處理資產及風險資料，避免資料錯誤或遺失。 |
| NFR-04 | 效能 | 一般查詢與結果顯示應於合理時間內完成，不造成明顯等待。 |
| NFR-05 | 可追溯性 | 系統應保留資產資料、評鑑結果與 AI 建議，以利後續查詢與追蹤。 |
| NFR-06 | 可維護性 | 系統功能模組應具備明確分工，方便後續修改與擴充。 |
| NFR-07 | AI 建議可解釋性 | AI 提供分類、CIA 價值或改善建議時，應呈現可供使用者判斷之理由。 |
| NFR-08 | 人工確認原則 | AI 輸出僅作為輔助建議，使用者可依實際情況確認或修正。 |

## 5-2 使用個案圖

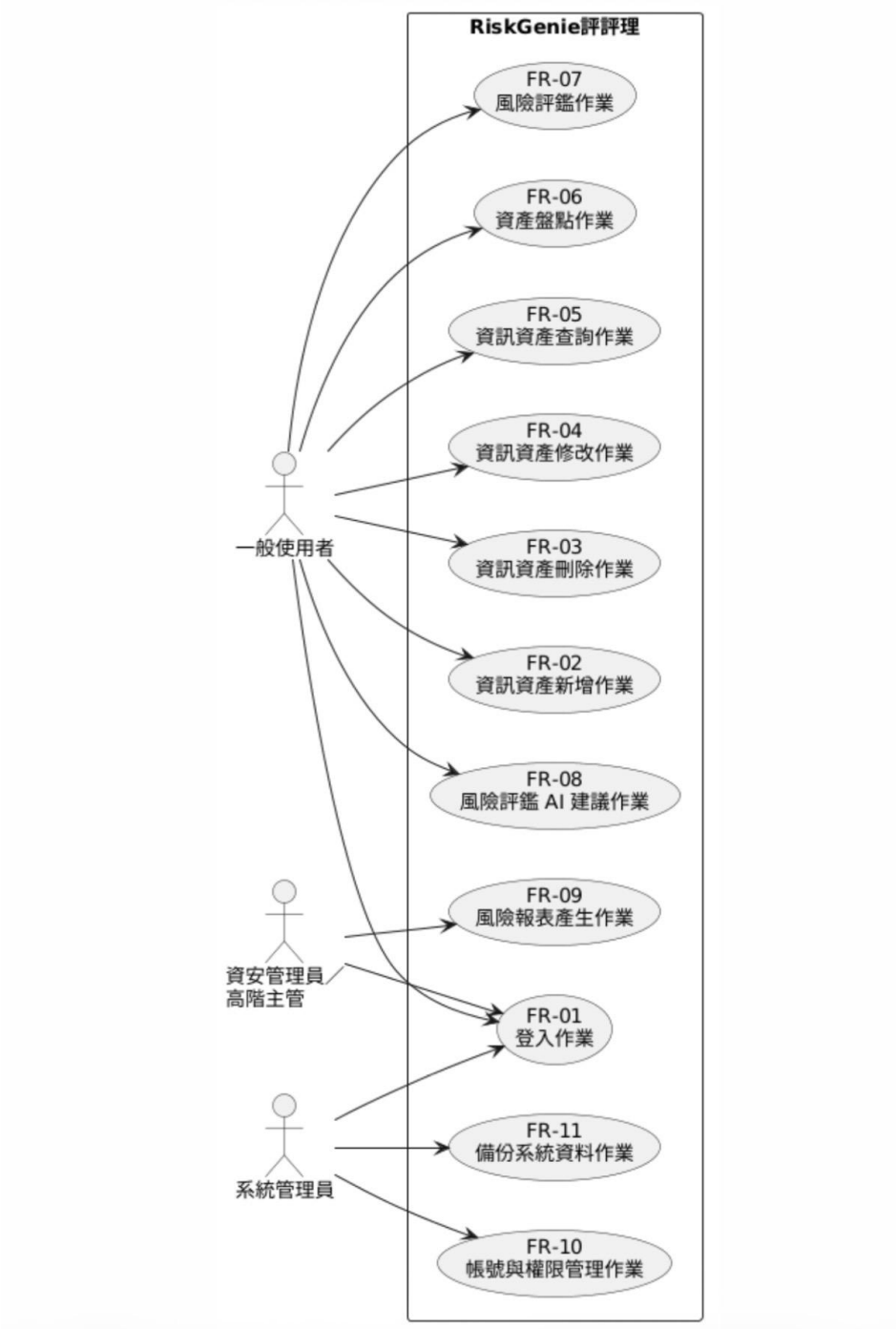



圖 5-2-1 使用個案圖

## 5-3 活動圖

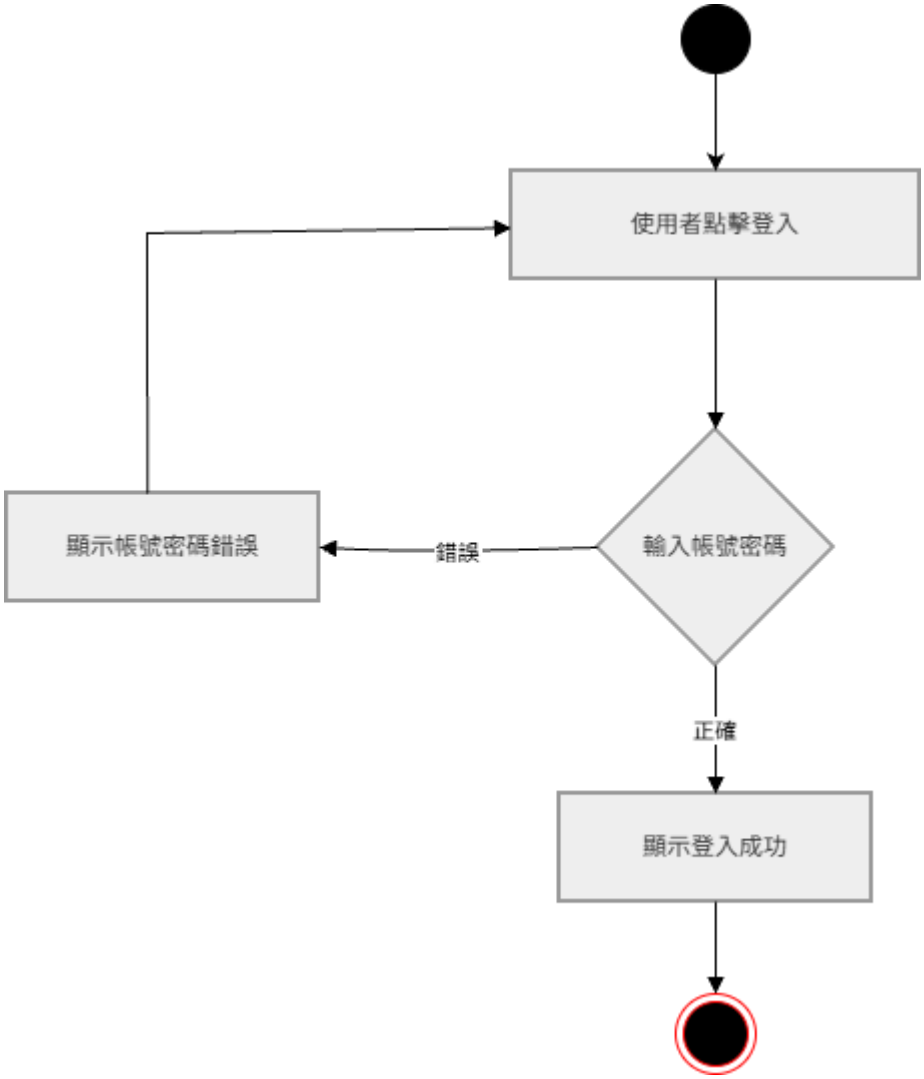



圖 5-3-1 活動圖－登入作業

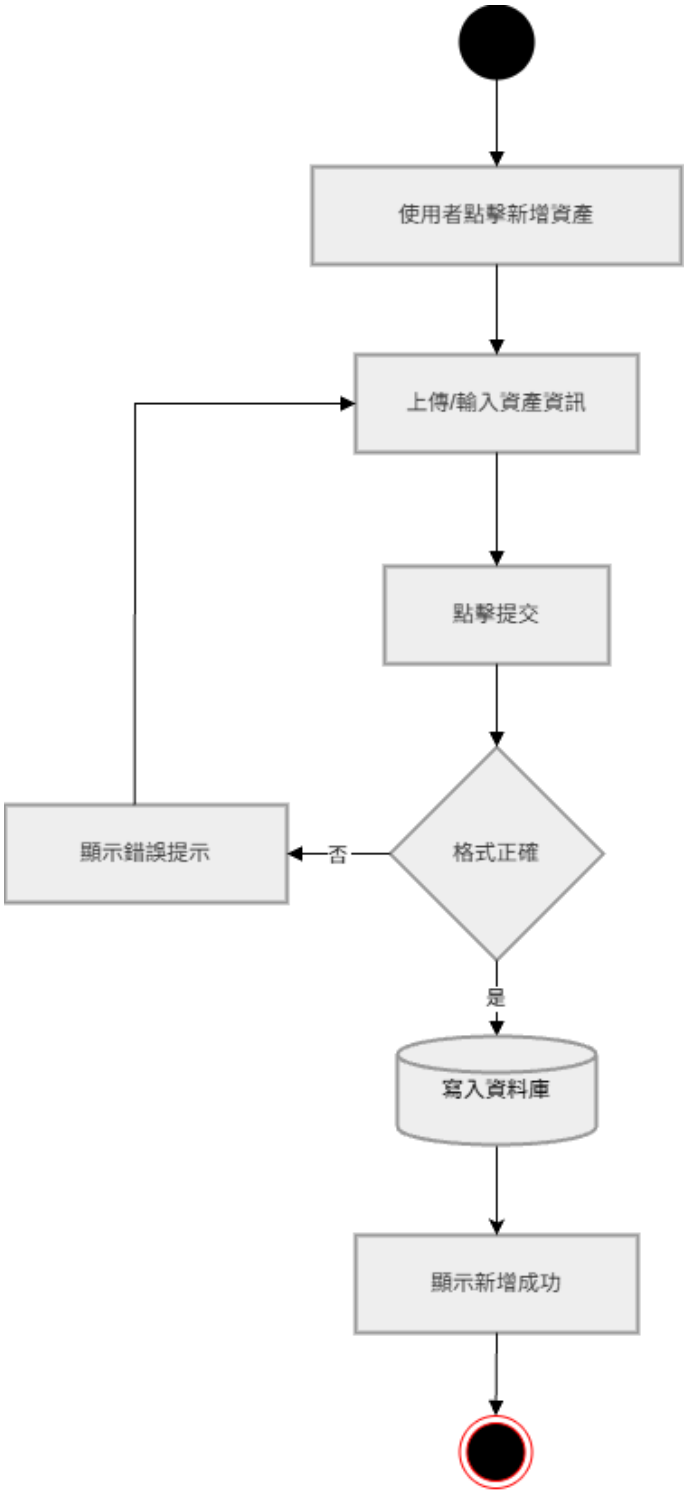



圖 5-3-2 活動圖－新增資訊資產作業

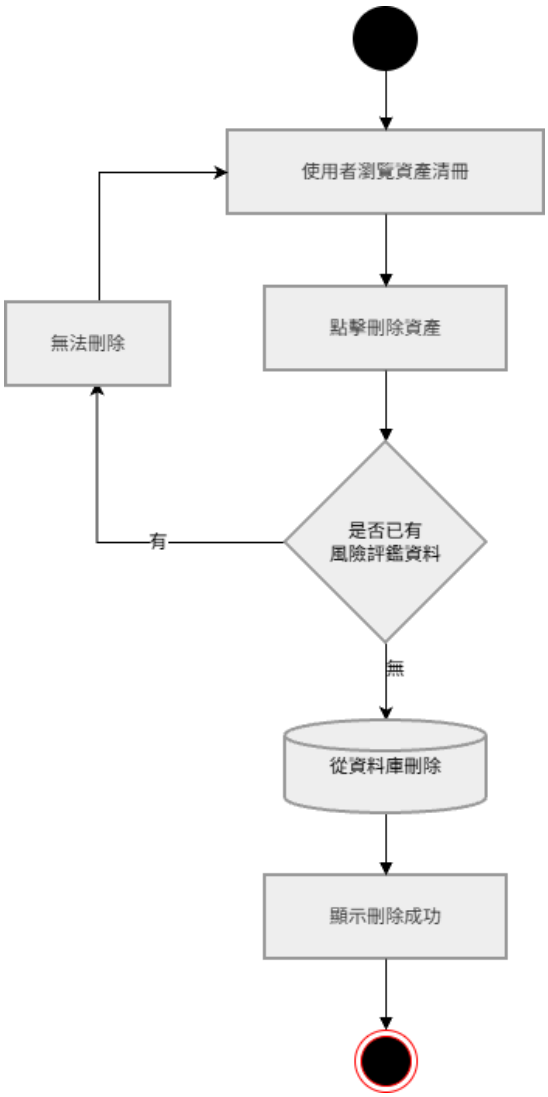



圖 5-3-3 活動圖－刪除資訊資產作業

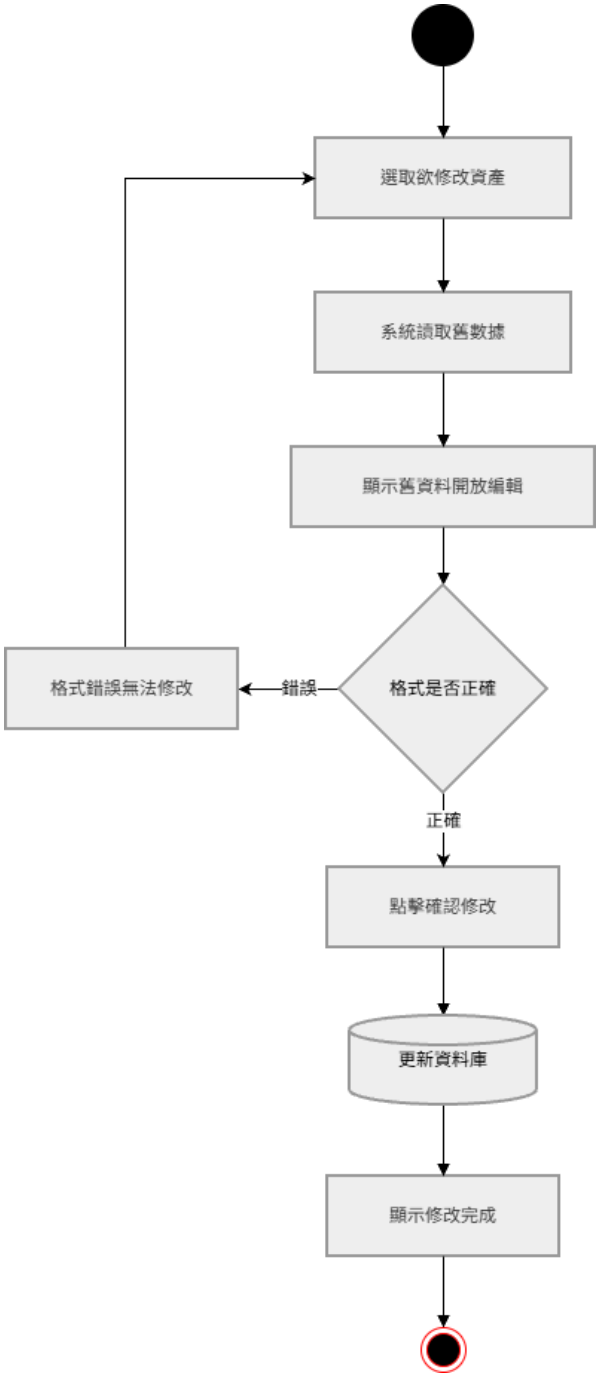



圖 5-3-4 活動圖－修改資訊資產作業

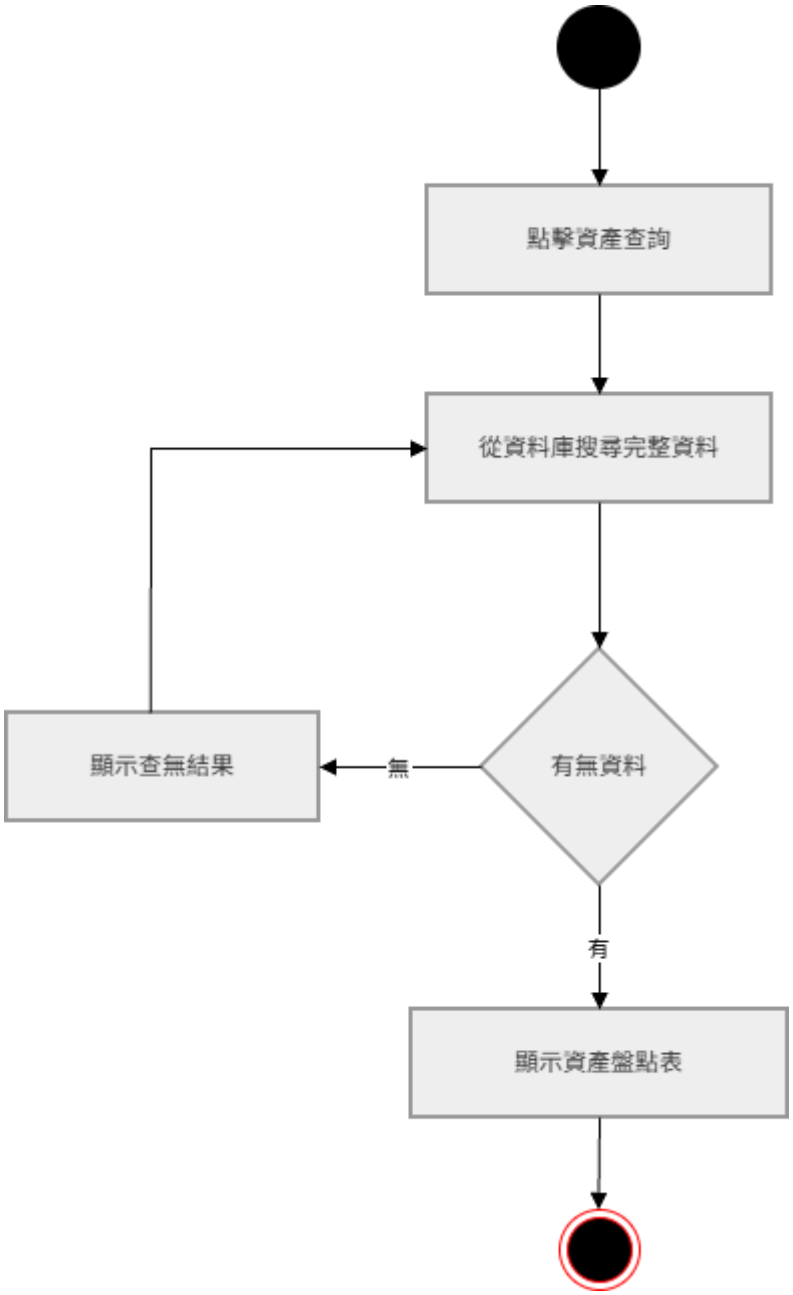



圖 5-3-5 活動圖－查詢資訊資產作業

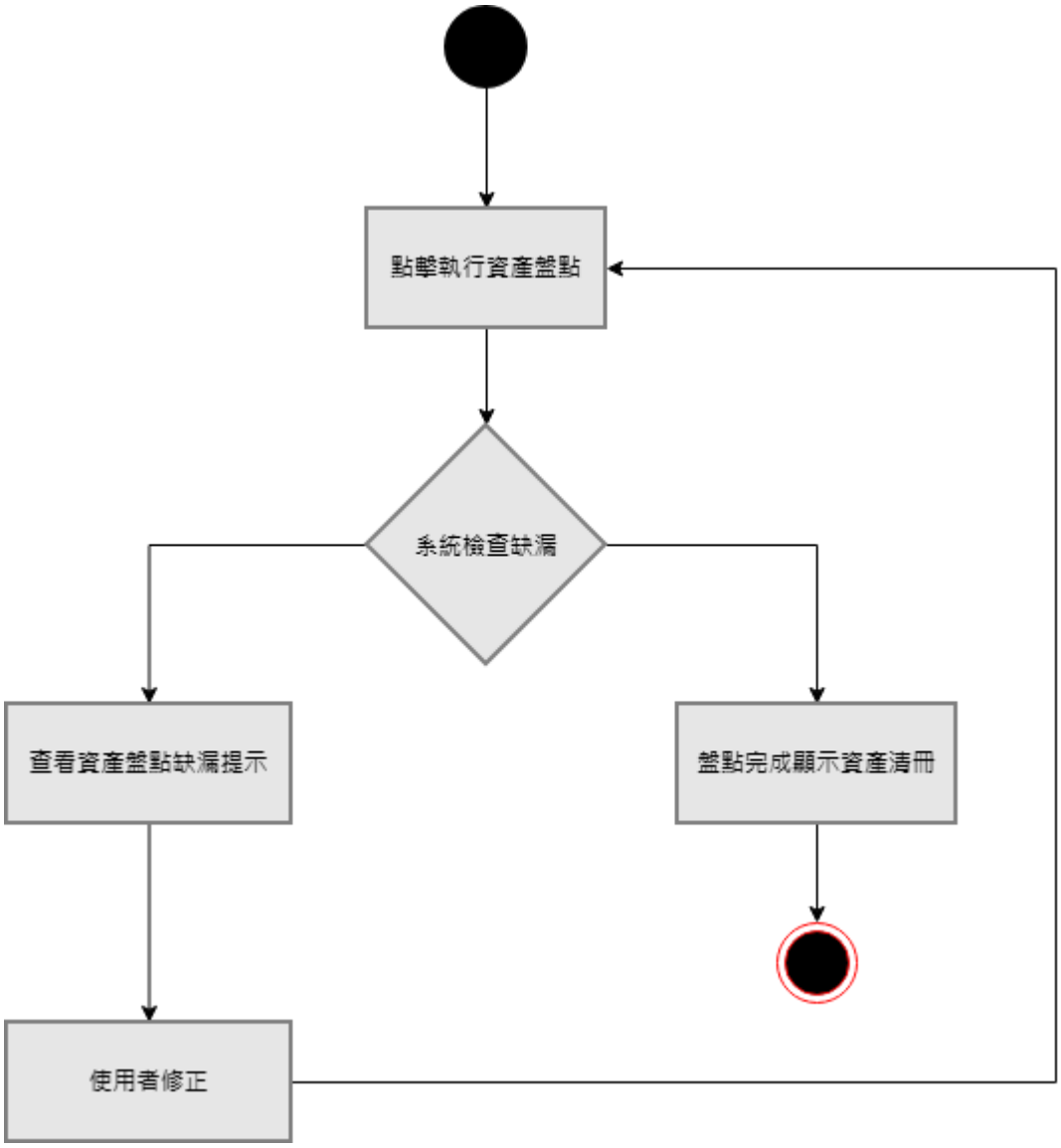



圖 5-3-6 活動圖－資產盤點作業

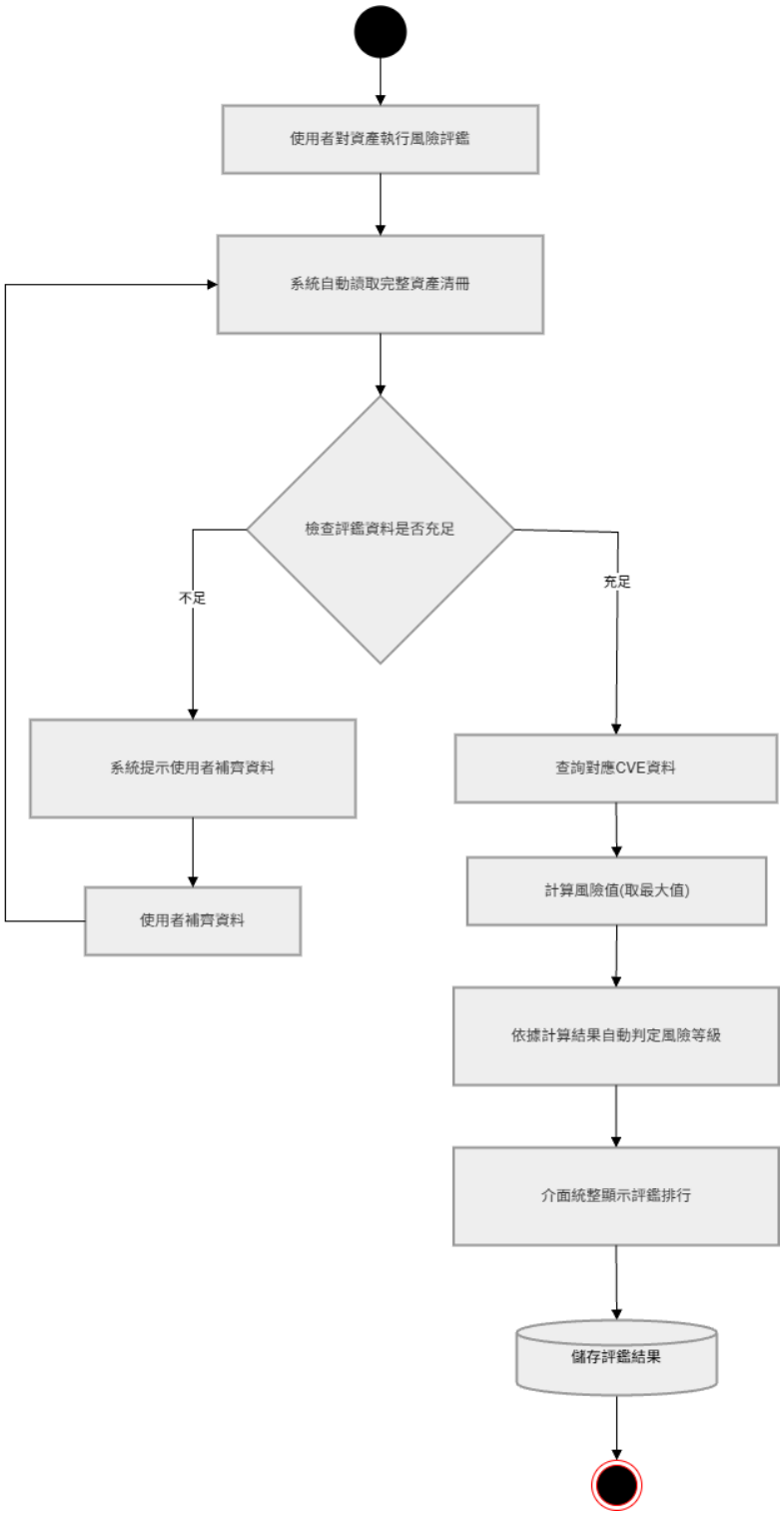



圖 5-3-7 活動圖－風險評鑑作業

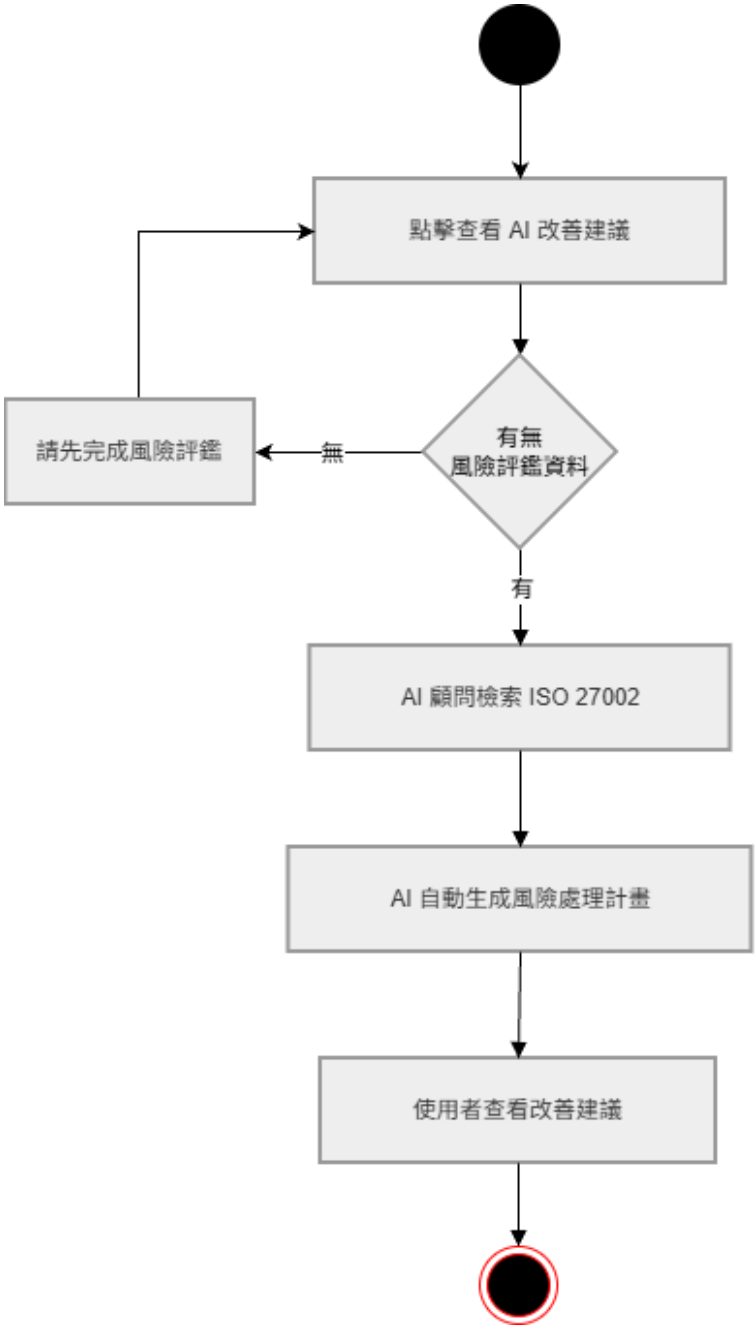



圖 5-3-8 活動圖－風險評鑑 AI 建議作業

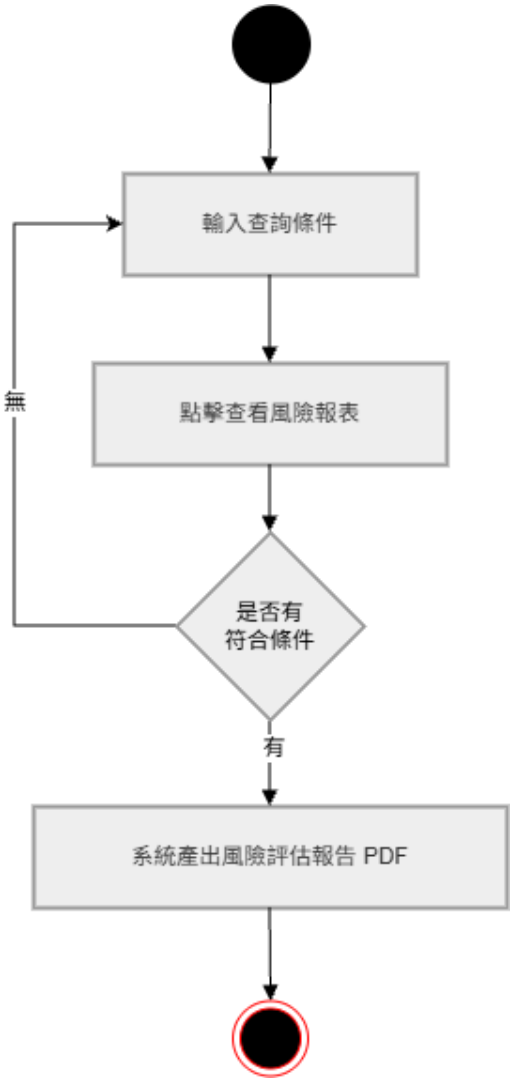



圖 5-3-9 活動圖－風險報表產生作業

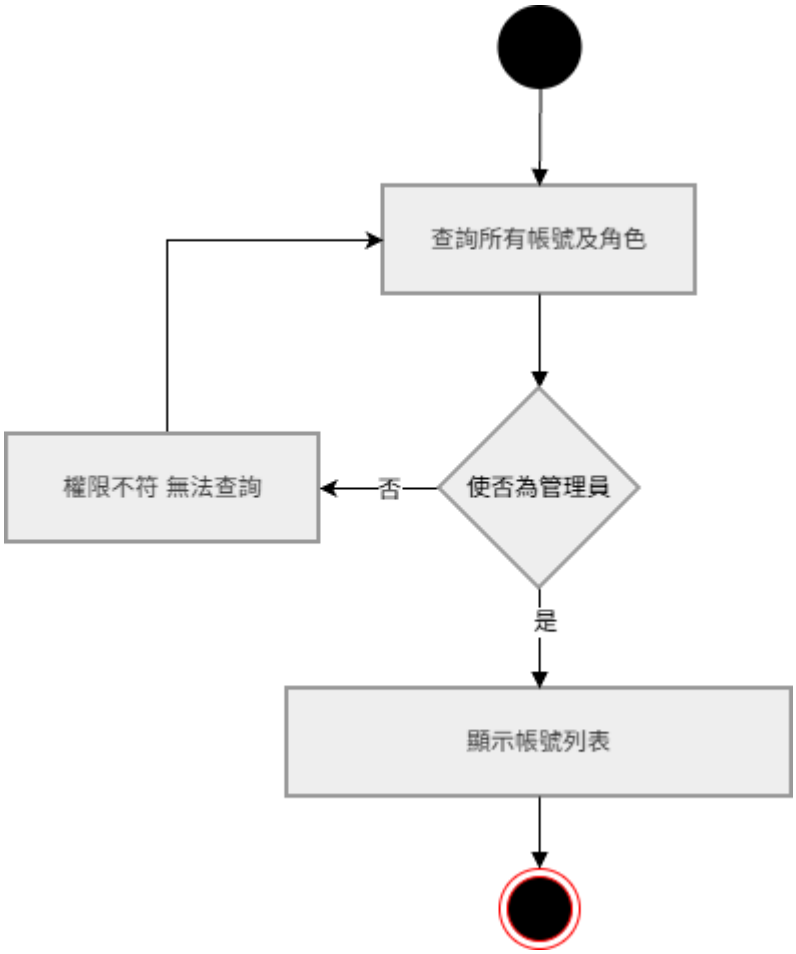



圖 5-3-10 活動圖－查詢帳號作業

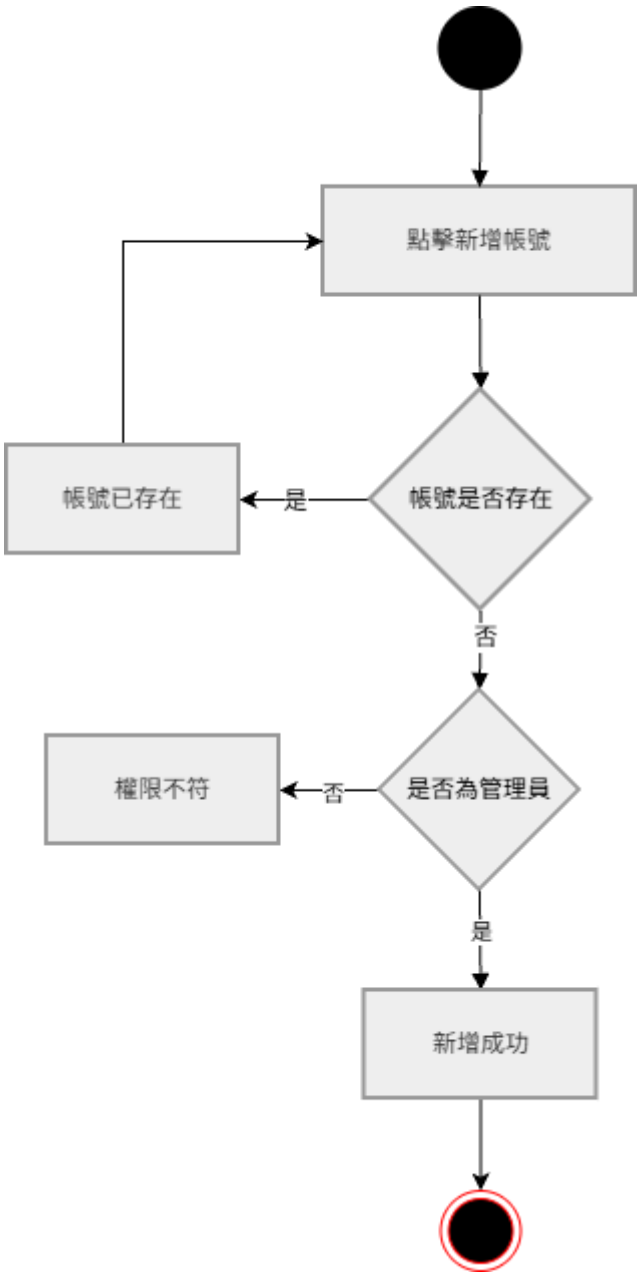



圖 5-3-11 活動圖－新增帳號作業

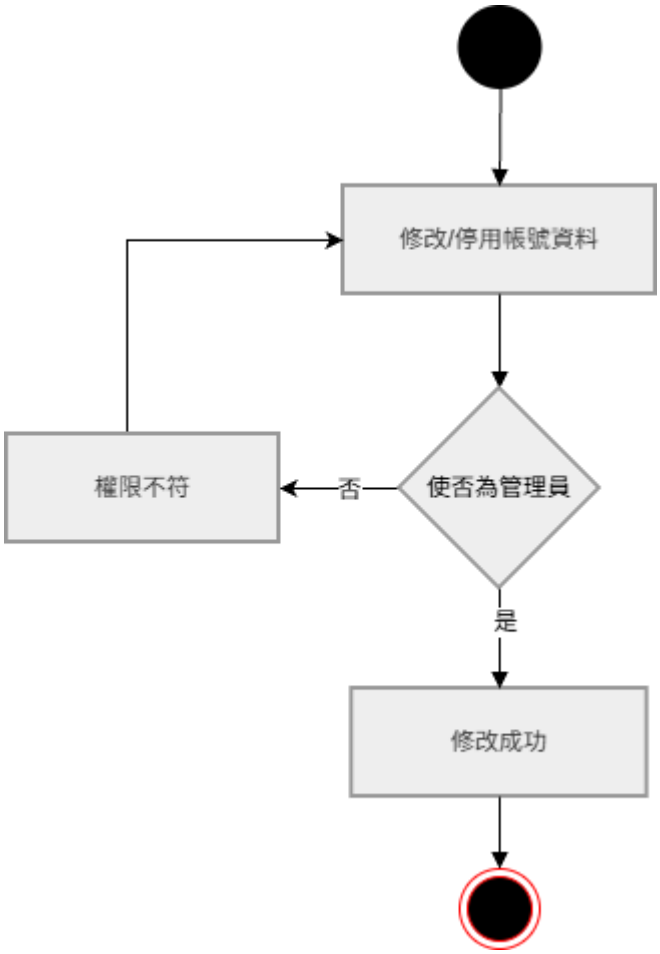



圖 5-3-12 活動圖－修改/停用帳號作業

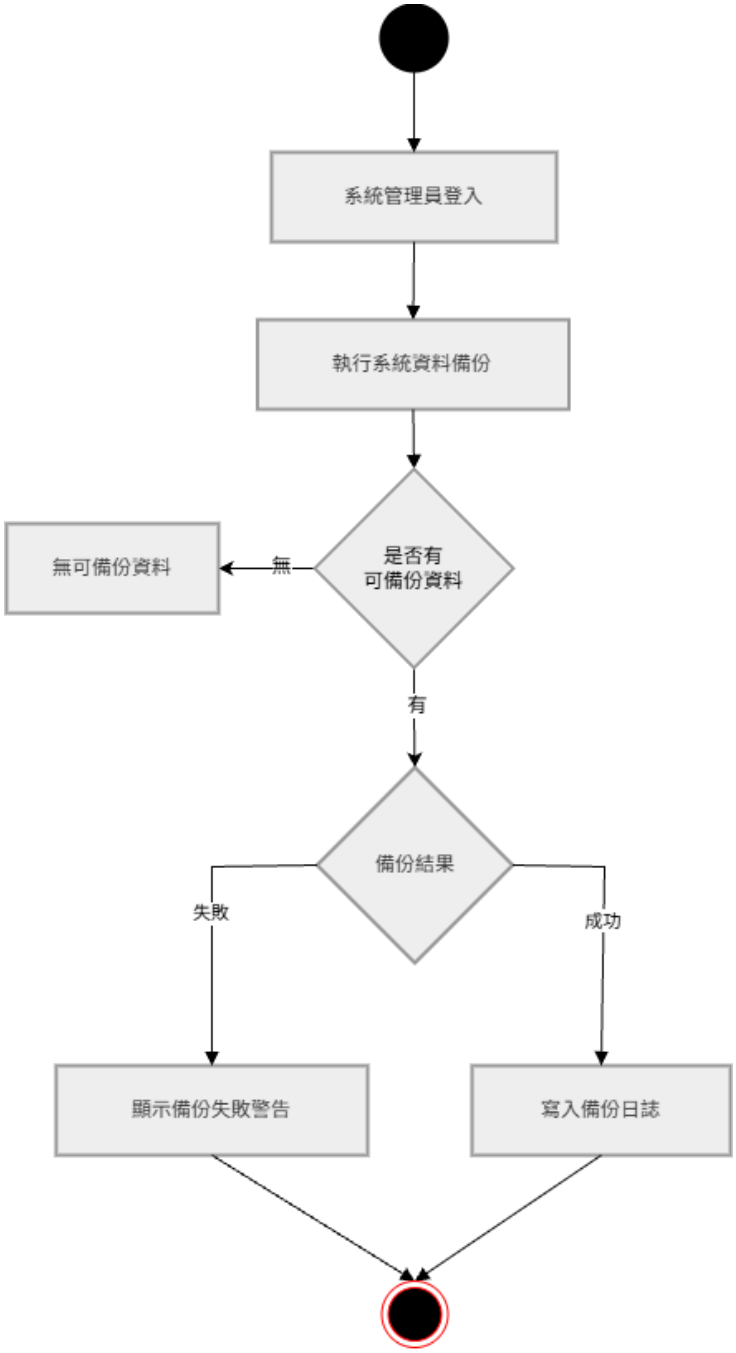



圖 5-3-13 活動圖－備份系統資料作業

# 5-4 分析類別圖

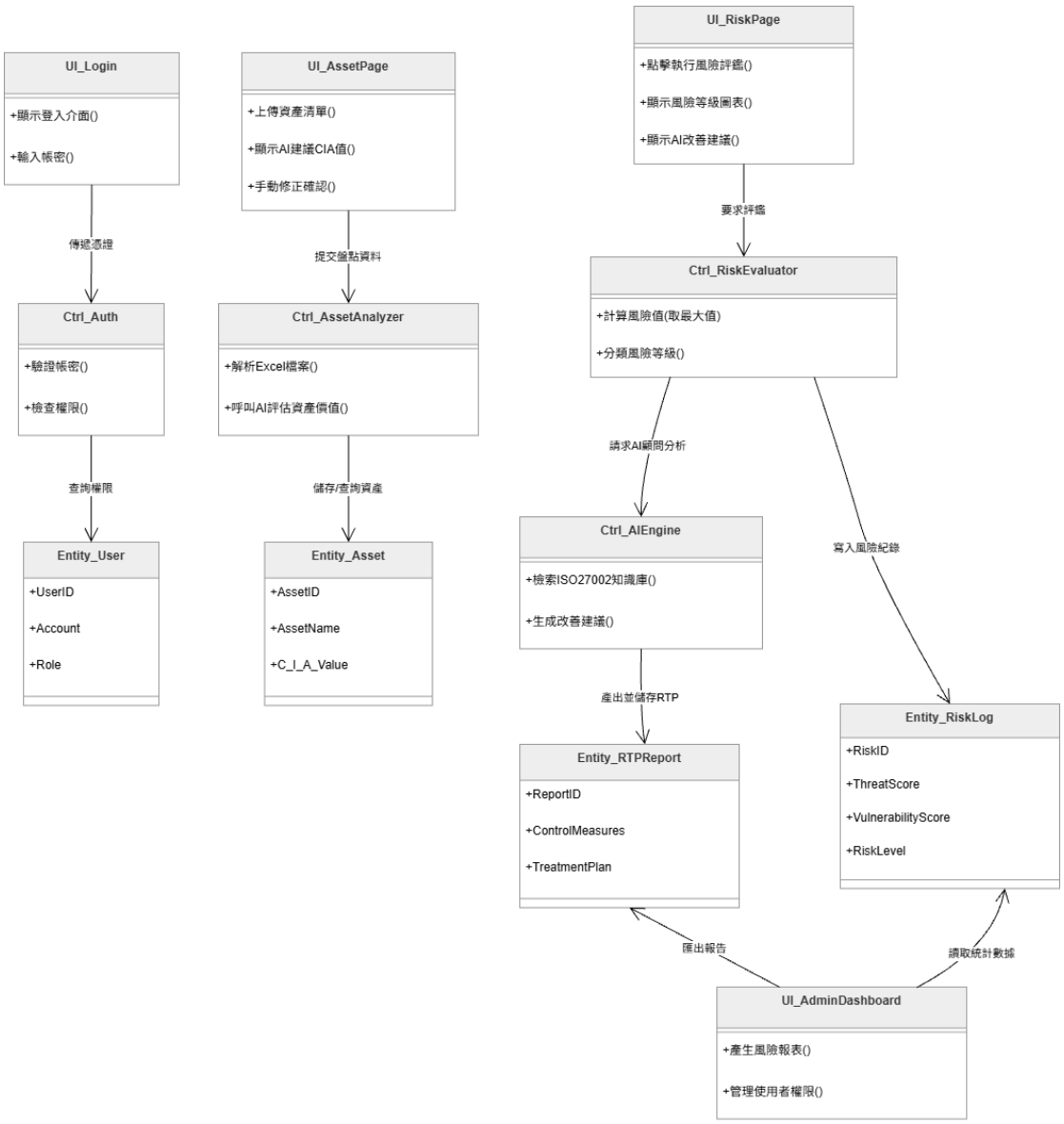



圖 5-4-1 分析類別圖

# 第 6 章 設計模型

## 6-1 循序圖

- 登入

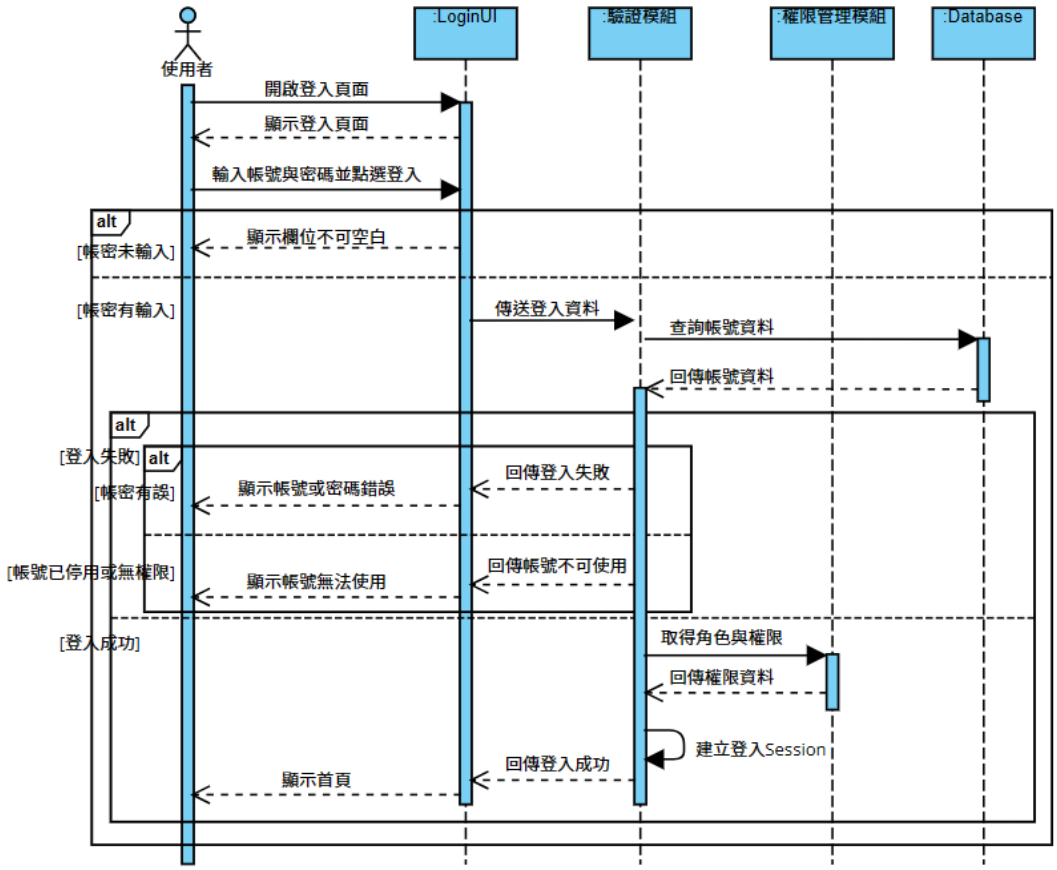



圖 6-1-1 循序圖－登入作業

- 資產盤點

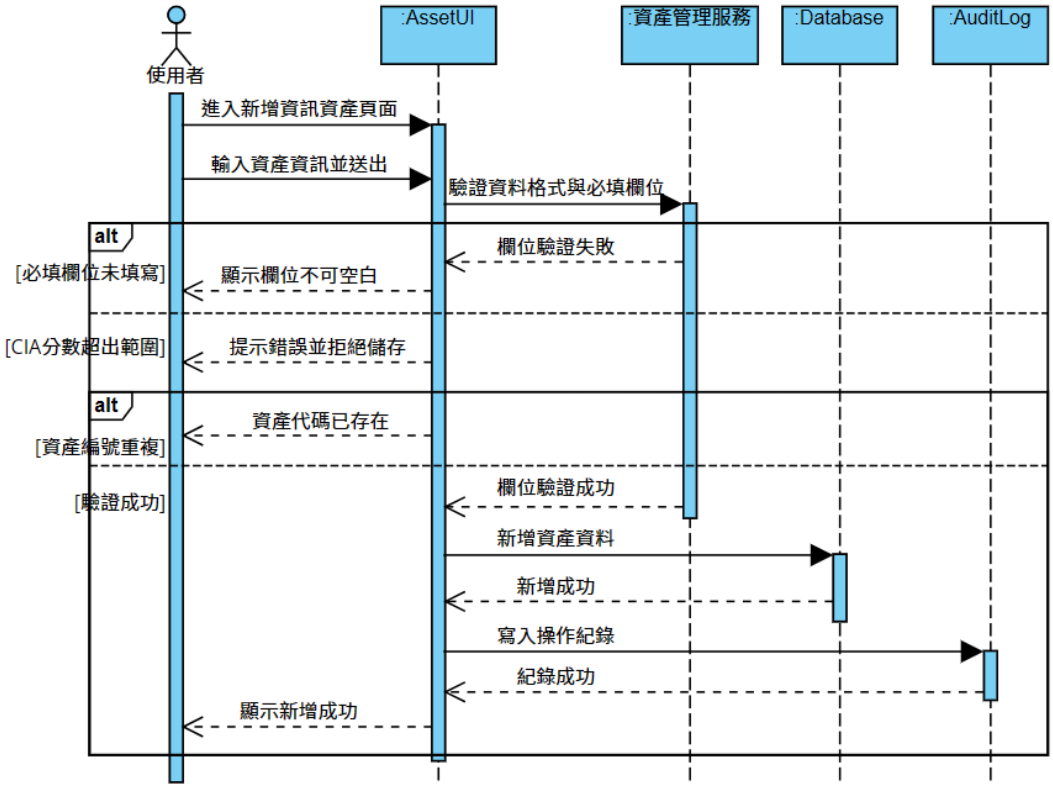



圖 6-1-2 循序圖－新增資訊資產作業

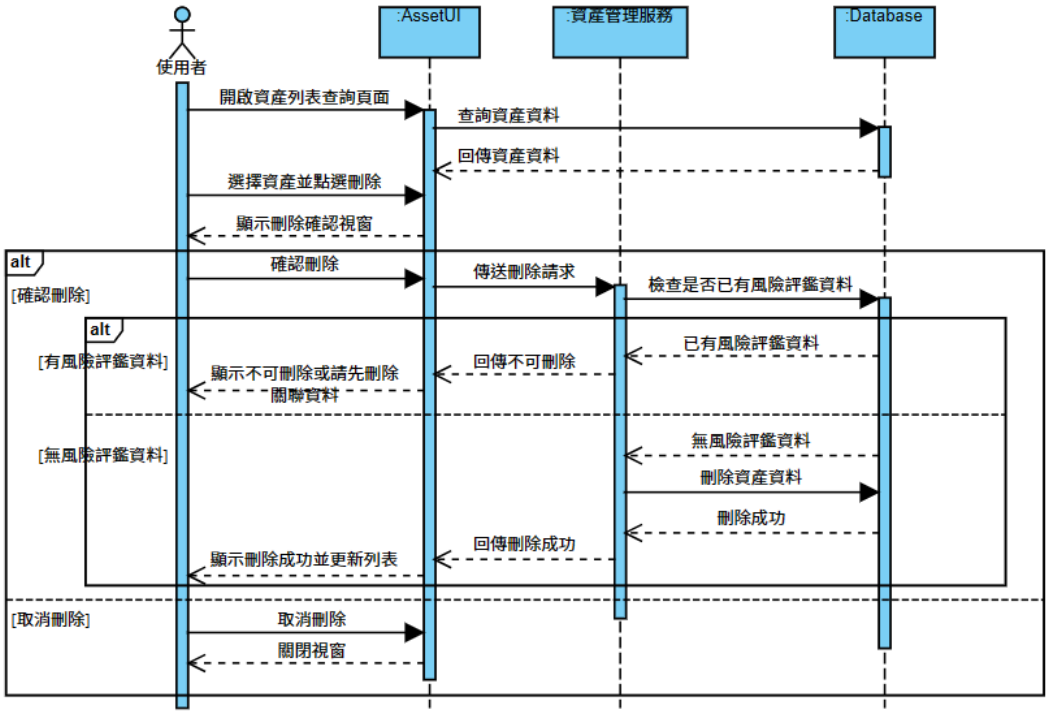



圖 6-1-3 循序圖－刪除資訊資產作業

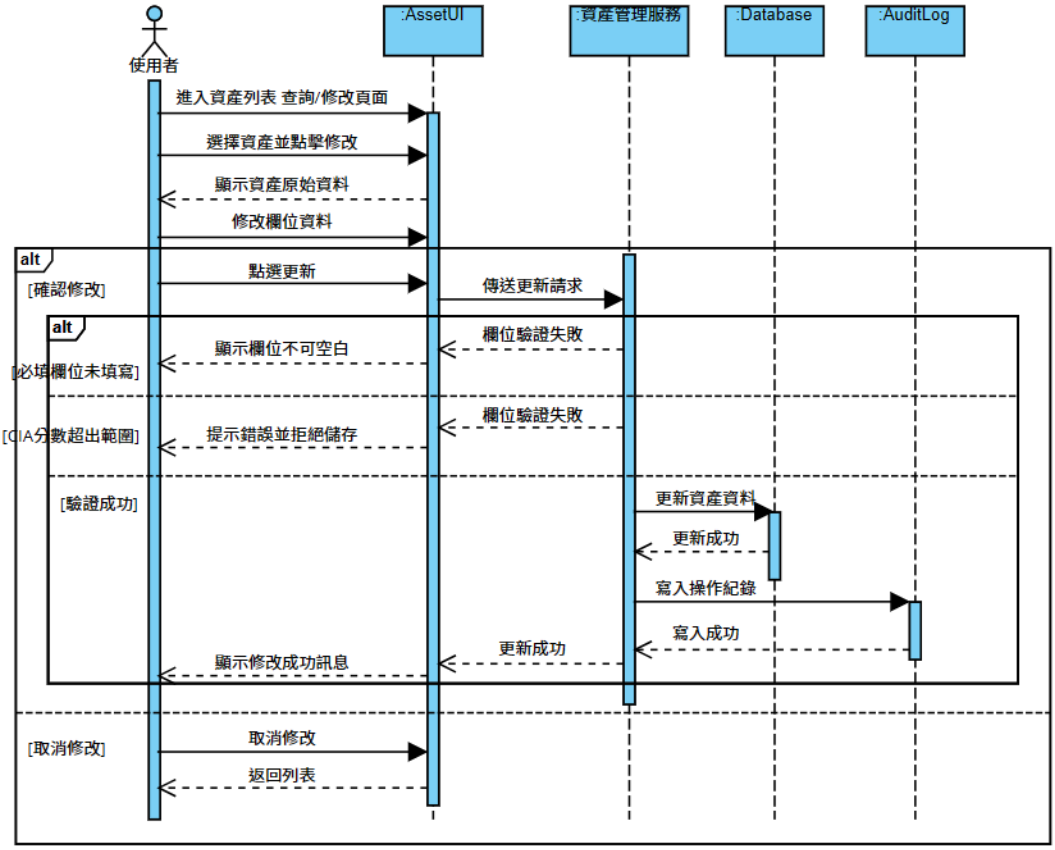



圖 6-1-4 循序圖－修改資訊資產作業

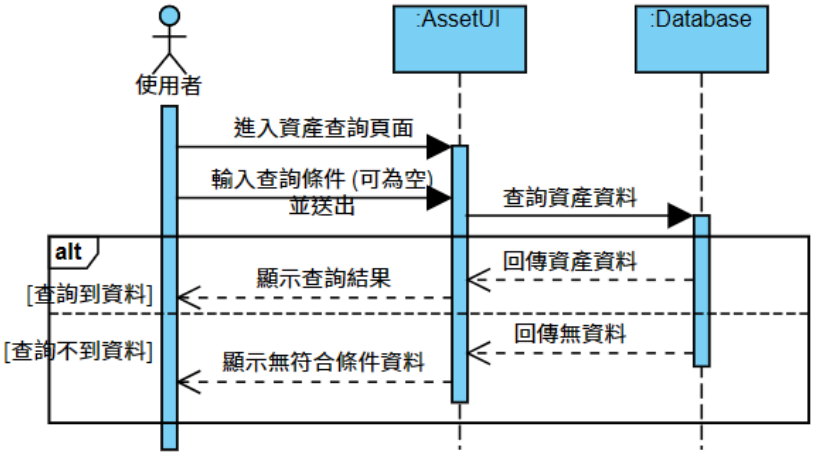



圖 6-1-5 循序圖－查詢資訊資產作業

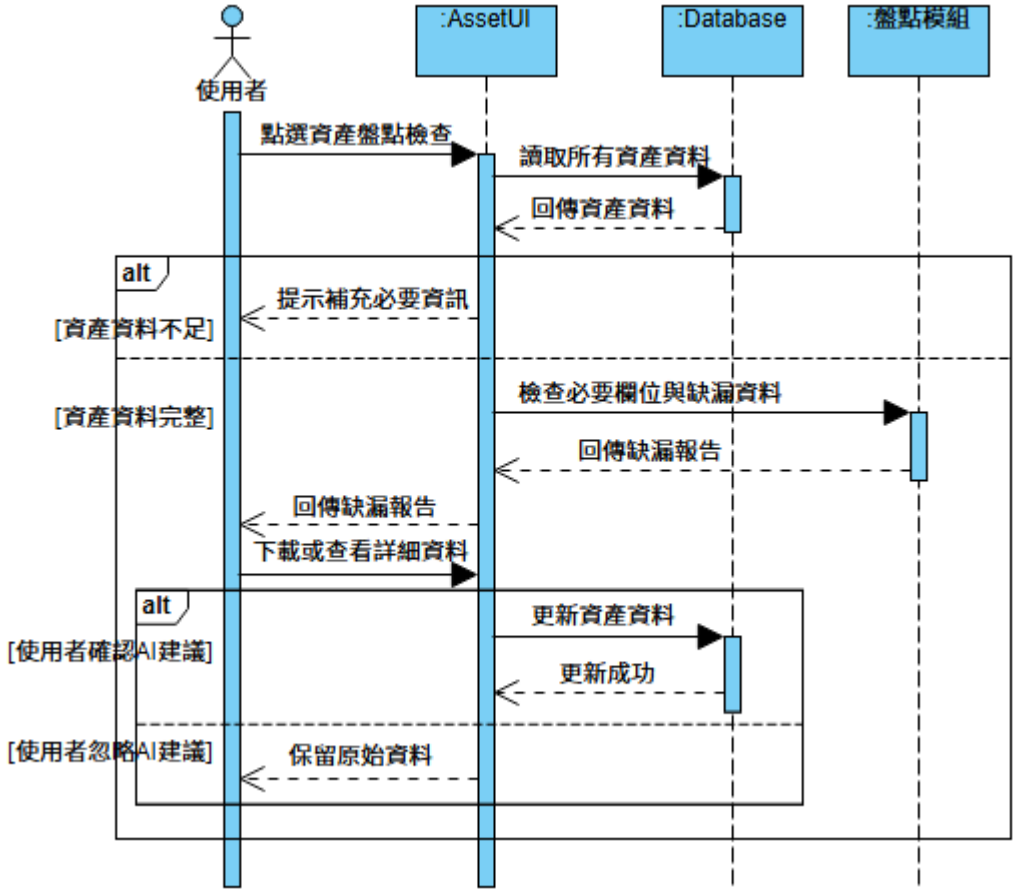



圖 6-1-6 循序圖－資產盤點作業

- 風險評鑑

本系統以北商情境為案例，並採用 CIAL 指標之最大值，結合 CVSS 分數，以計算系統之風險評分。

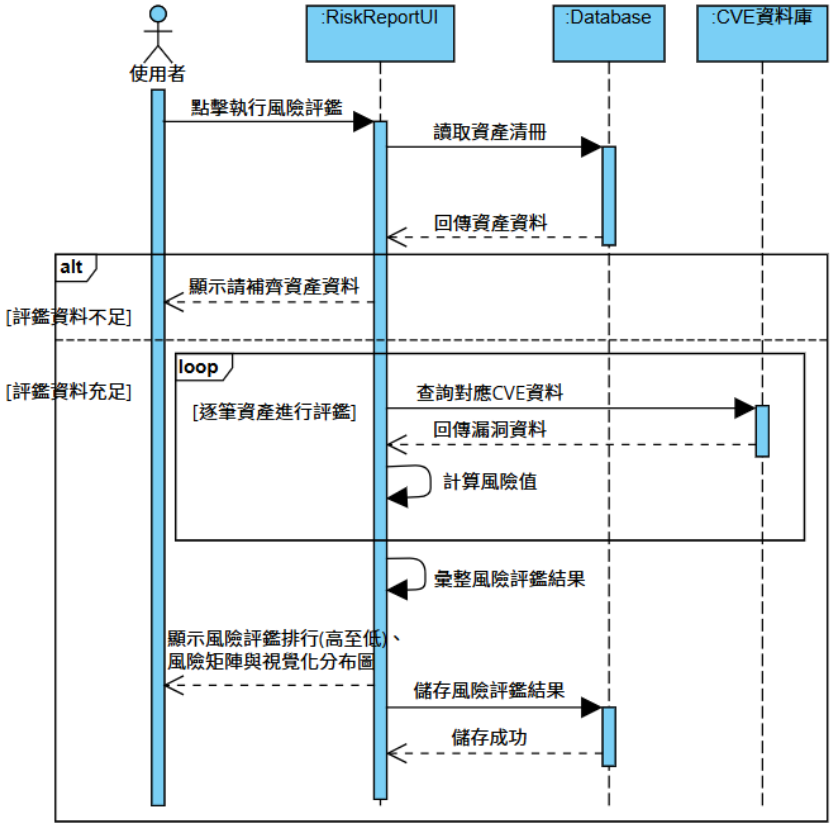



圖 6-1-7 循序圖－風險評鑑作業

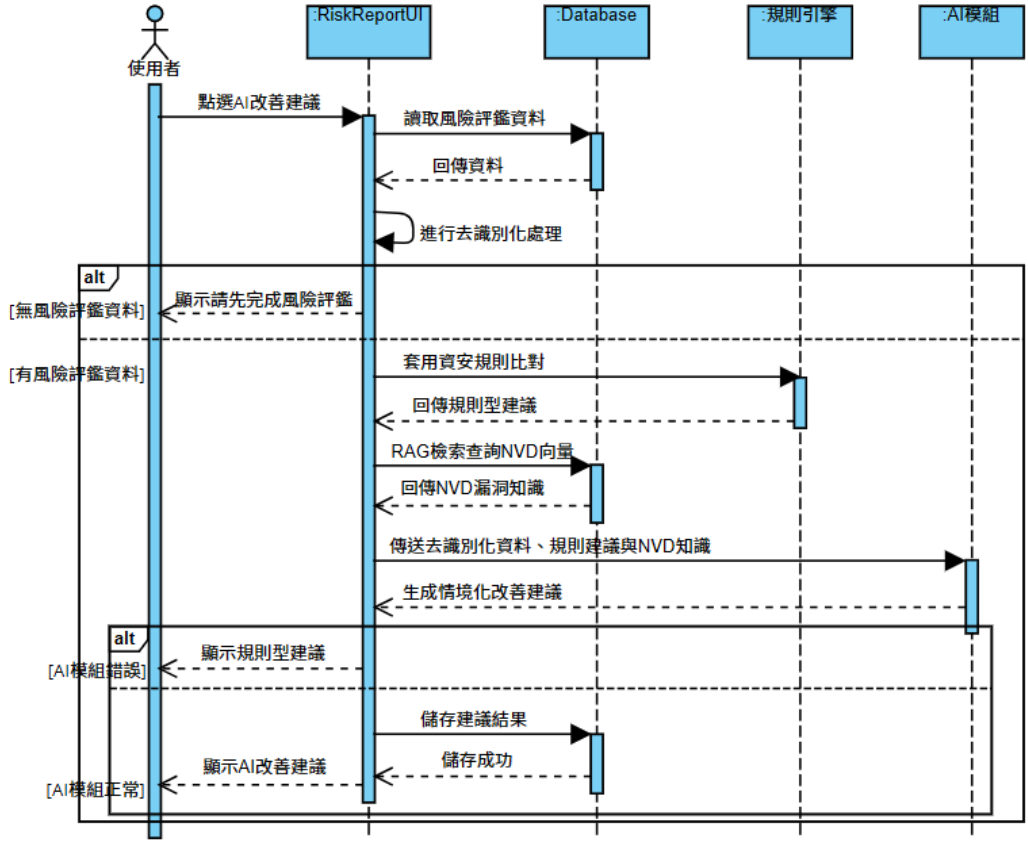



圖 6-1-8 循序圖－風險評鑑 AI 建議作業

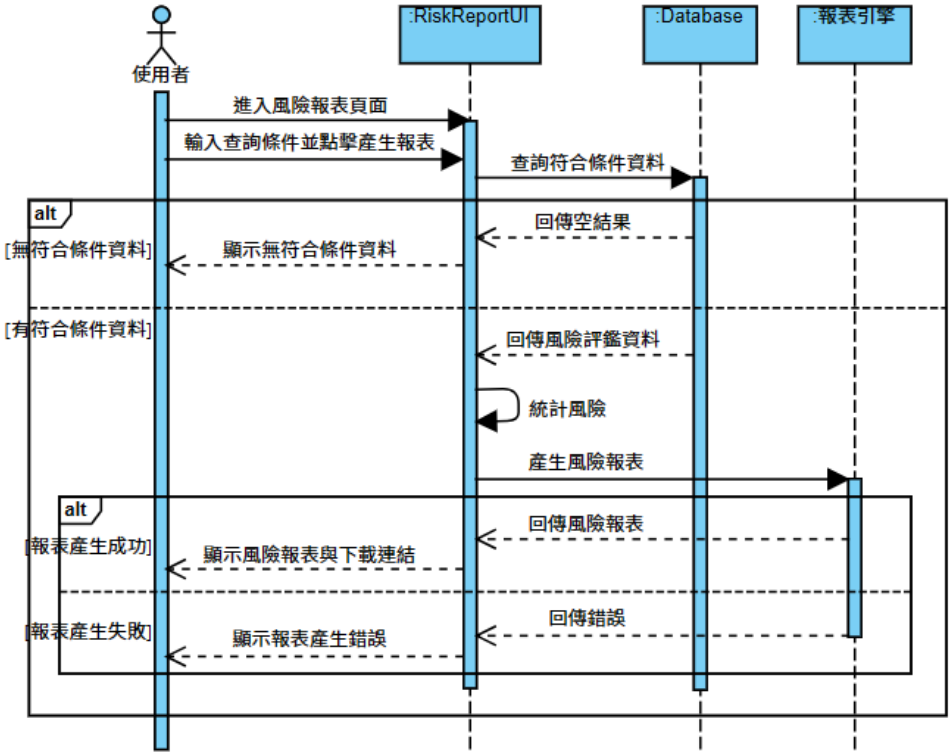



圖 6-1-9 循序圖－風險報表產生作業

- 帳號與權限管理

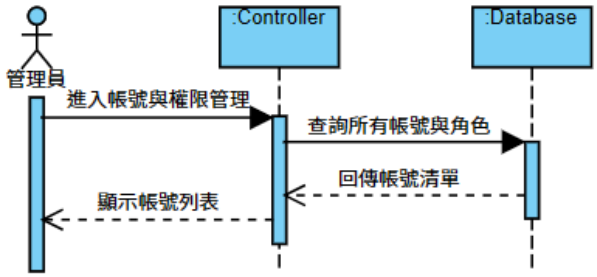



圖 6-1-10 循序圖－查詢帳號作業

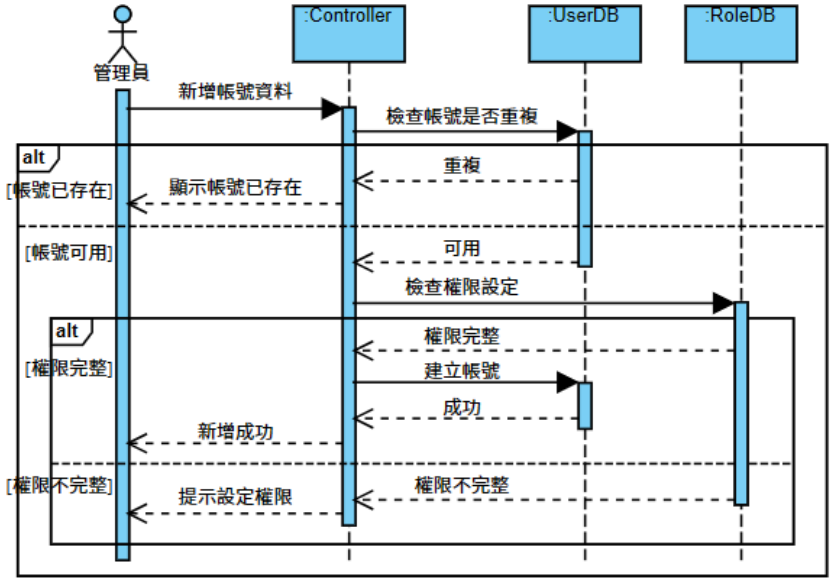



圖 6-1-11 循序圖－新增帳號作業

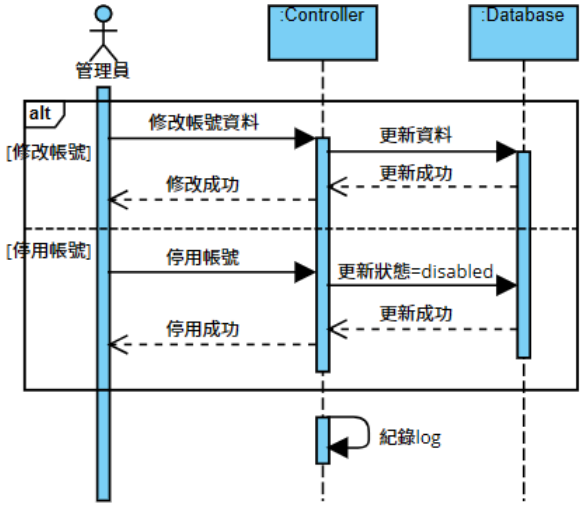



圖 6-1-12 循序圖－修改/停用帳號作業

- 備份

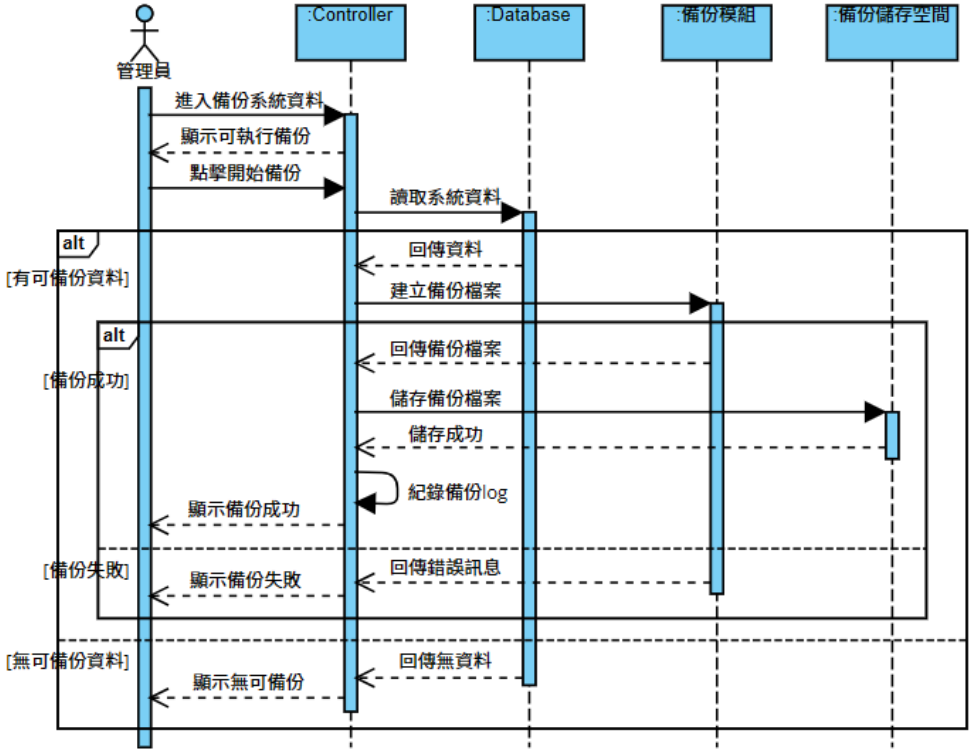



圖 6-1-13 循序圖－備份系統資料作業

# 6-2 設計類別圖

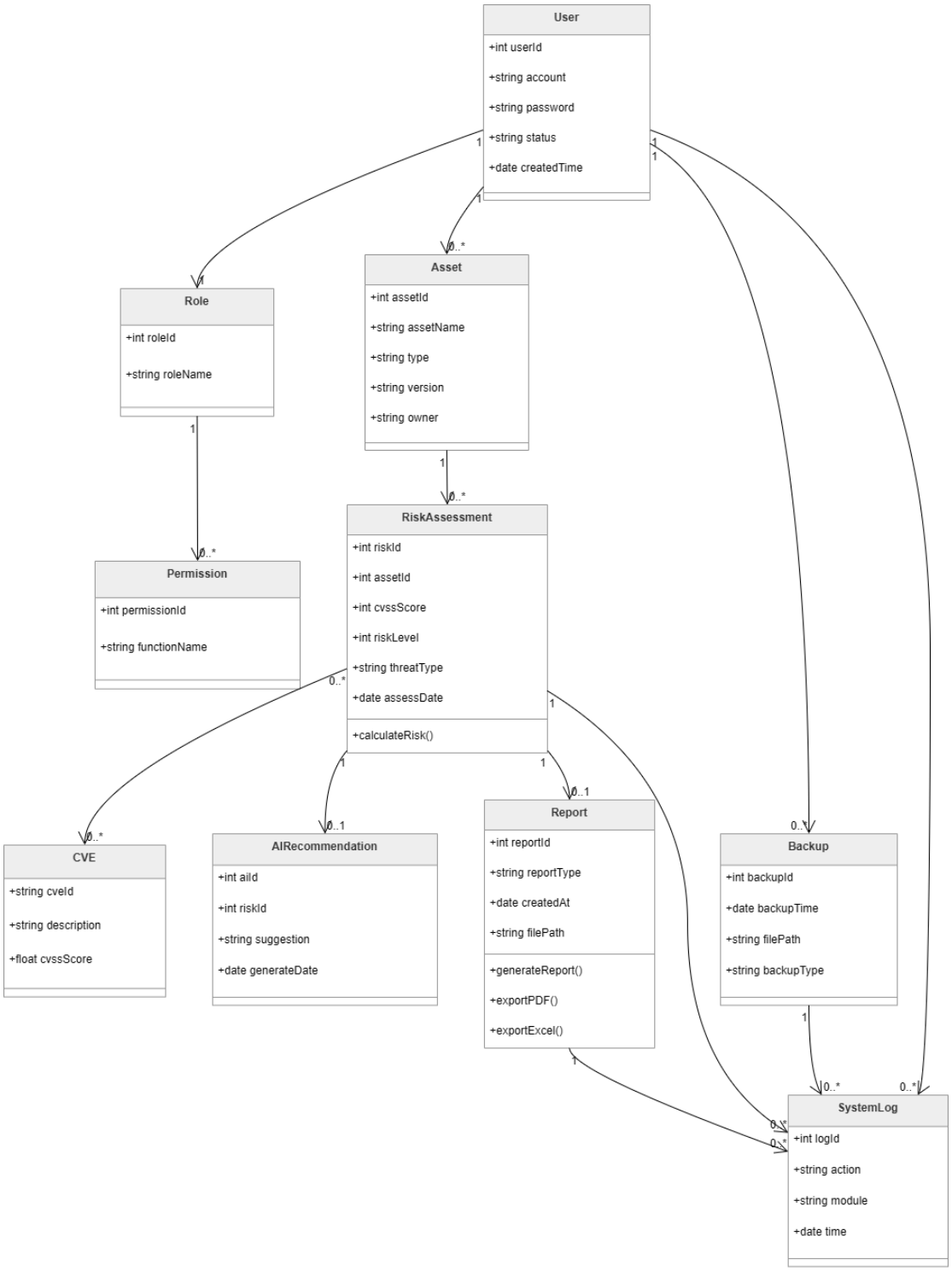



圖 6-2-1 設計類別圖

# 第 7 章 實作模型

## 7-1 佈署圖

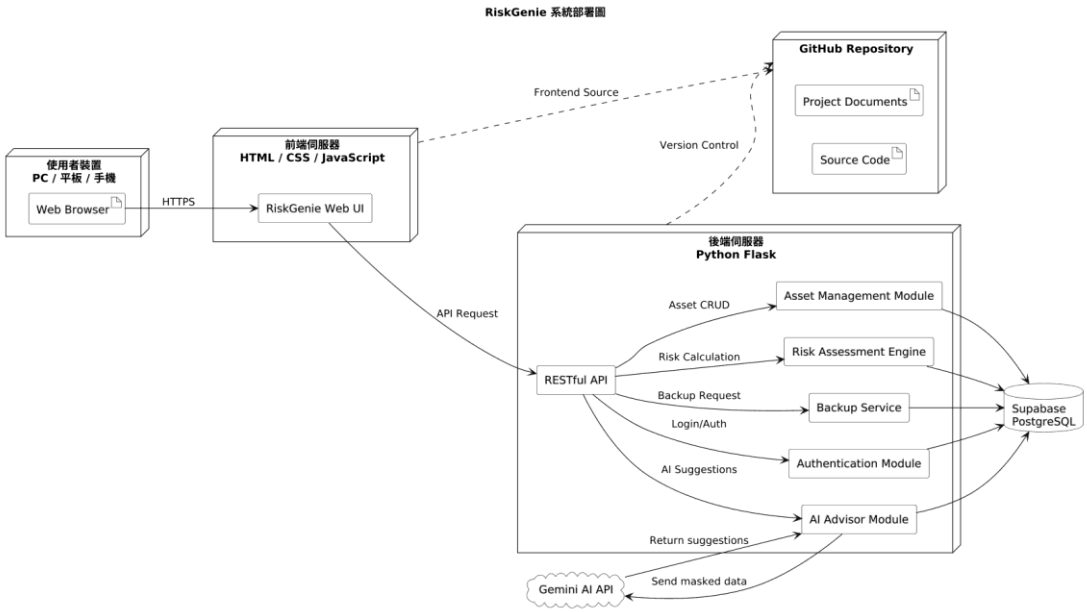



圖 7-1-1 佈署圖

## 7-2 套件圖

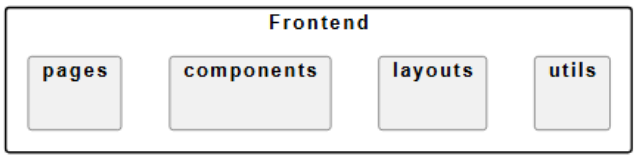



圖 7-2-1 前端套件圖

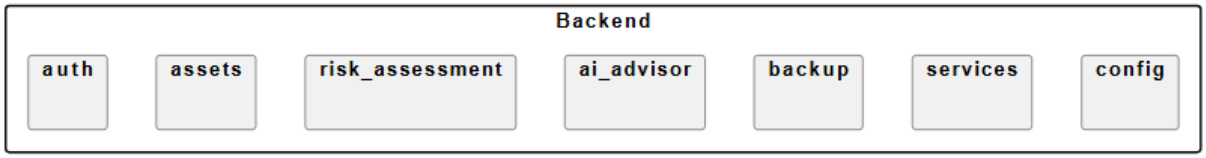






圖 7-2-2 後端套件圖

## 7-3 元件圖

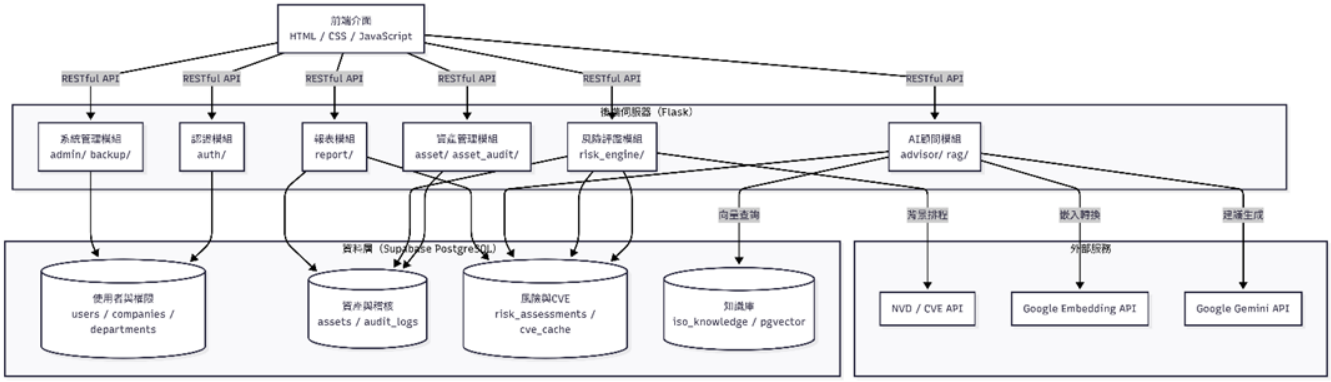



圖 7-3-1 元件圖

# 7-4 狀態機圖與時序圖

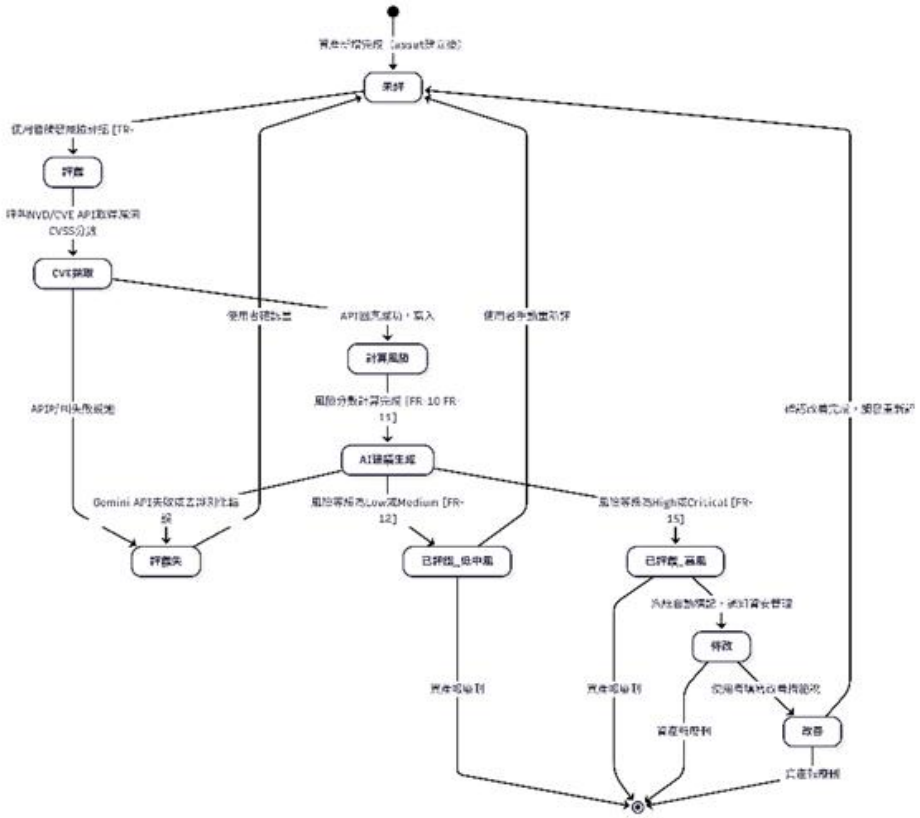



圖 7-4-1 狀態機圖

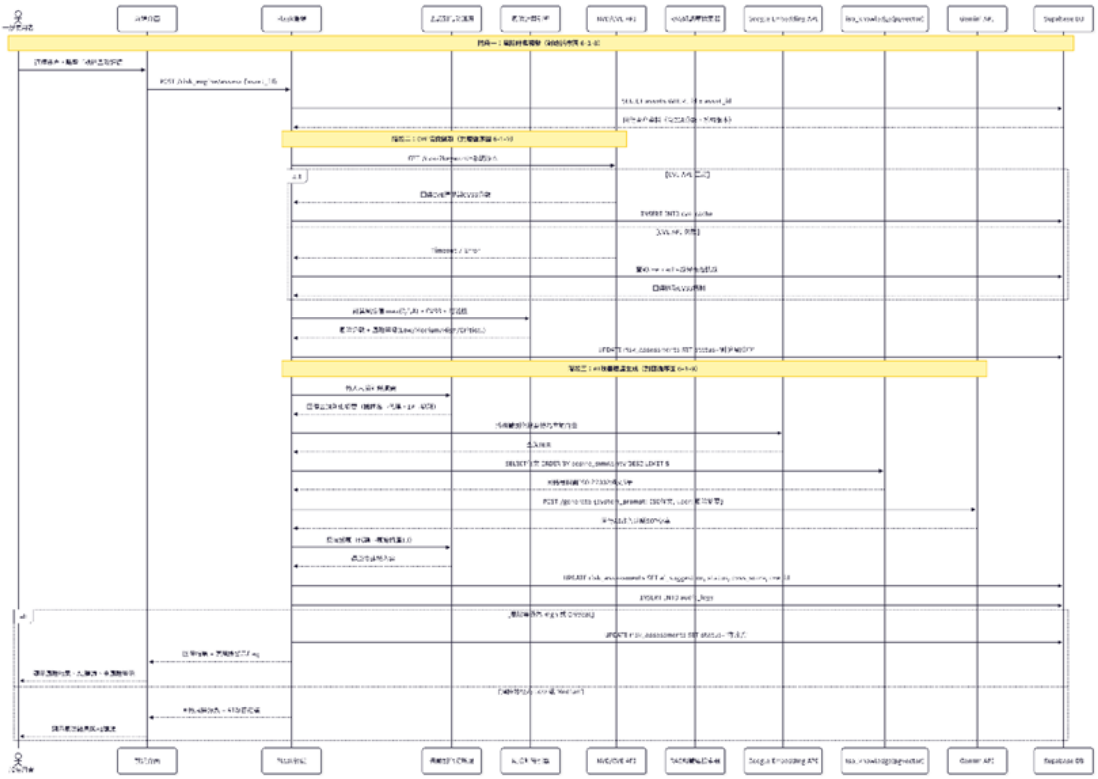
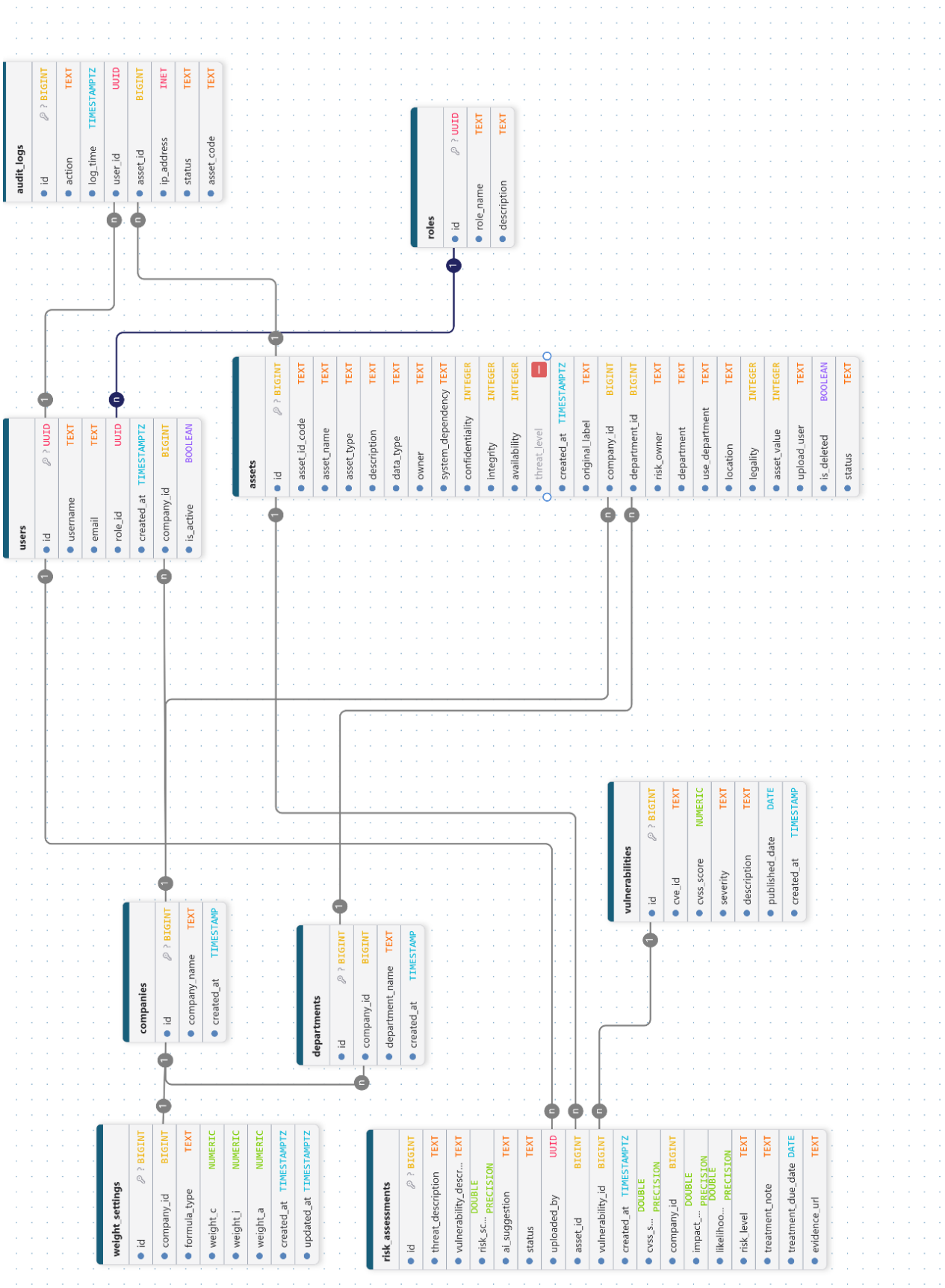


圖 7-4-2 時序圖

# 第 8 章　資料庫設計

## 8-1　資料庫關聯表（參考關係與限制 Constraints）



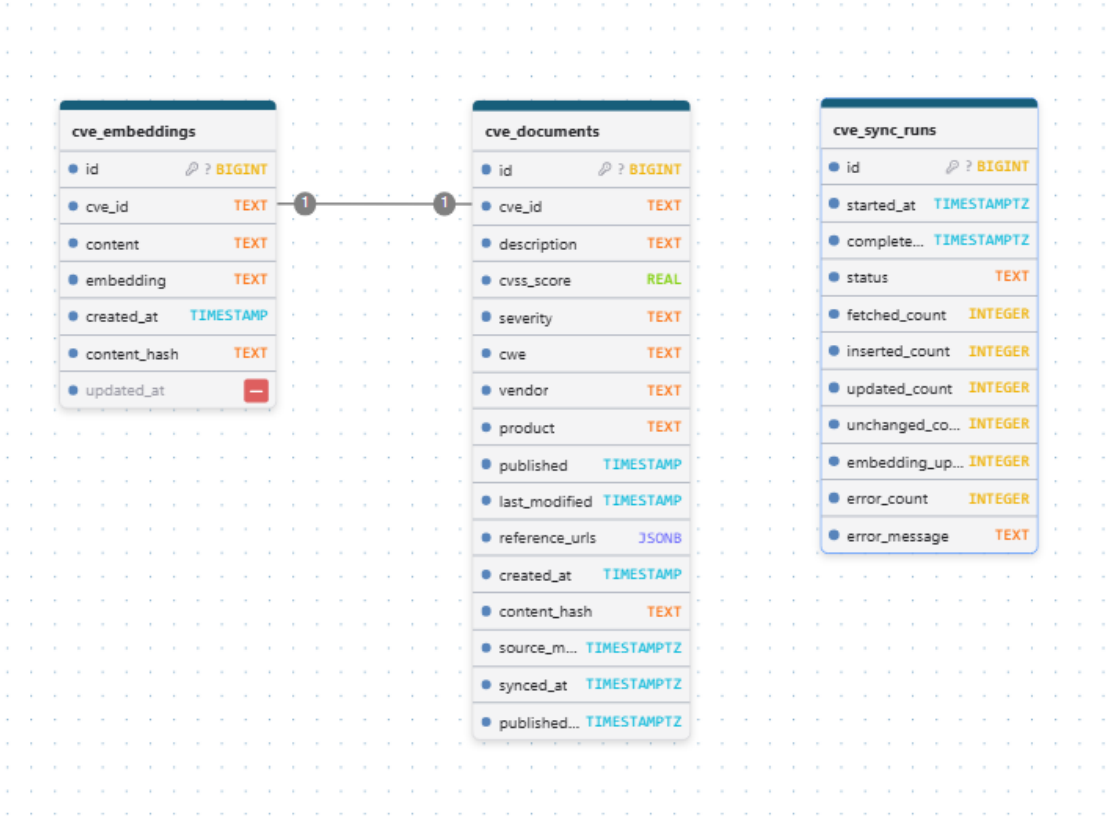



圖 8-1-1 資料庫關聯表

## 8-2 表格及其 Meta Data

表 8-2-1 assets (資產表) 欄位定義

| 欄位名稱 | 欄位型態 | 是否可空 | 描述 | 備註 |
|---|---|---|---|---|
| id | int8 | 否 | 資產唯一識別碼 | Primary / Identity |
| asset_id_code | text | 是 | 資產代碼（如公司自訂編號） | Unique |
| asset_name | text | 否 | 資產名稱 | |
| asset_type | text | 否 | 資產類型 | |
| description | text | 是 | 資產描述 | |
| data_type | text | 是 | 資料類型 | |
| owner | text | 是 | 資產擁有者 | |
| system_dependency | text | 是 | 系統依賴關係 | |
| confidentiality | int4 | 否 | 機密性等級 | |
| integrity | int4 | 否 | 完整性等級 | |
| availability | int4 | 否 | 可用性等級 | |
| threat_level | text | 是 | 威脅等級 | |
| created_at | timestamptz | 是 | 建立時間 | Default: now() |

| | | | | |
|---|---|---|---|---|
| original_label | text | 是 | 原始標籤 | |
| company_id | int8 | 是 | 所屬公司 ID | FK → companies.id |
| department_id | int8 | 是 | 所屬部門 ID | FK → departments.id |
| risk_owner | text | 是 | 保管單位（風險擁有者） | |
| department | text | 是 | 權責單位 | |
| use_department | text | 是 | 使用單位 | |
| location | text | 是 | 放置地點 | |
| legality | int4 | 否 | 適法性 L | |
| asset_value | int4 | 是 | 資產價值＝CIAL 最大值 | |
| upload_user | text | 是 | 上傳者 | |
| is_deleted | bool | 是 | 是否已刪除 | |
| status | text | 是 | 資產狀態 | |

表 8-2-2 audit_logs (稽核紀錄表) 欄位定義

| 欄位名稱 | 欄位型態 | 是否可空 | 描述 | 備註 |
|---|---|---|---|---|
| id | int8 | 否 | 稽核紀錄唯一識別碼 | Primary / Identity |
| action | text | 是 | 操作／動作（新增/修改/刪除） | |
| log_time | timestamptz | 是 | 紀錄時間 | |
| user_id | uuid | 是 | 使用者 ID | FK → users.id |
| asset_id | int8 | 是 | 資產 ID | FK → assets.id |
| ip_address | inet | 是 | IP 位址 | |
| status | text | 是 | 操作結果狀態(成功/失敗) | |
| asset_code | text | 是 | 資產代碼 | |

表 8-2-3 companies (公司表) 欄位定義

| 欄位名稱 | 欄位型態 | 是否可空 | 描述 | 備註 |
|---|---|---|---|---|
| id | int8 | 否 | 公司唯一識別碼 | PK, Identity |
| company_name | text | 否 | 公司名稱 | |
| created_at | timestamp | 是 | 建立時間 | Default: now() |

表 8-2-4 cve_documents (CVE 漏洞文件資料表) 欄位定義

| 欄位名稱 | 欄位型態 | 是否可空 | 描述 | 備註 |
|---|---|---|---|---|
| id | int8 | 否 | CVE 文件唯一識別碼 | Primary |
| cve_id | text | 否 | CVE 漏洞識別碼 | Unique |
| description | text | 是 | 漏洞描述 | |
| cvss_score | float4 | 是 | CVSS 漏洞評分 | |
| severity | text | 是 | 漏洞嚴重程度 | |
| cwe | text | 是 | CWE 弱點類型 | |

| | | | | |
|---|---|---|---|---|
| vendor | text | 是 | 廠商 | |
| product | text | 是 | 產品 | |
| published | timestamp | 是 | 公開時間 | |
| last_modified | timestamp | 是 | 最後修改時間 | |
| reference_urls | jsonb | 是 | 參考網址 | |
| created_at | timestamp | 是 | 建立時間 | Default: now() |
| content_hash | text | 是 | 內容雜湊值 | |
| source_modified_at | timestamptz | 是 | 來源資料最後修改時間 | |
| synced_at | timestamptz | 是 | 同步時間 | |
| published_at | timestamptz | 是 | 發布時間 | |

表 8-2-5 cve_embeddings (CVE 漏洞向量資料表) 欄位定義

| 欄位名稱 | 欄位型態 | 是否可空 | 描述 | 備註 |
|---|---|---|---|---|
| id | int8 | 否 | CVE 嵌入資料唯一識別碼 | Primary |
| cve_id | text | 是 | CVE 漏洞識別碼 | FK → cve_documents.cve_id、Unique |
| content | text | 是 | 漏洞文字內容 | |
| embedding | vector | 是 | 漏洞內容的向量嵌入值 | |
| created_at | timestamp | 是 | 建立時間 | Default: now() |
| content_hash | text | 是 | 內容雜湊值 | |
| updated_at | timestamptz | 是 | 更新時間 | |

表 8-2-6 cve_sync_runs (CVE 同步紀錄表) 欄位定義

| 欄位名稱 | 欄位型態 | 是否可空 | 描述 | 備註 |
|---|---|---|---|---|
| id | int8 | 否 | CVE 同步紀錄唯一識別碼 | Primary / Identity |
| started_at | timestamptz | 否 | 同步開始時間 | |
| completed_at | timestamptz | 是 | 同步完成時間 | |
| status | text | 否 | 同步狀態 | |
| fetched_count | int4 | 否 | 取得的 CVE 資料筆數 | |
| inserted_count | int4 | 否 | 新增的 CVE 資料筆數 | |
| updated_count | int4 | 否 | 更新的 CVE 資料筆數 | |
| unchanged_count | int4 | 否 | 未變更的 CVE 資料筆數 | |
| embedding_updated_count | int4 | 否 | 更新向量嵌入的筆數 | |
| error_count | int4 | 否 | 發生錯誤的筆數 | |
| error_message | text | 是 | 錯誤訊息 | |

表 8-2-7 departments (部門表) 欄位定義

| 欄位名稱 | 欄位型態 | 是否可空 | 描述 | 備註 |
|---|---|---|---|---|
| id | int8 | 否 | 部門唯一識別碼 | Primary / Identity |
| company_id | int8 | 否 | 所屬公司 ID | FK → companies.id |
| department_name | text | 否 | 部門名稱 | |
| created_at | timestamp | 是 | 建立時間 | Default: now() |

表 8-2-8 risk_assessments (AI 風險分析結果表) 欄位定義

| 欄位名稱 | 欄位型態 | 是否可空 | 描述 | 備註 |
|---|---|---|---|---|
| id | int8 | 否 | 風險評鑑唯一識別碼 | Primary / Identity |
| threat_description | text | 是 | 威脅描述 | |
| vulnerability_description | text | 是 | 漏洞描述 | |
| risk_score | float8 | 是 | 風險分數 | |
| ai_suggestion | text | 是 | AI 改善建議 | |
| status | text | 是 | 風險處理狀態 | |
| uploaded_by | uuid | 是 | 上傳／建立評鑑者 | FK → users.id |
| asset_id | int8 | 是 | 資產 ID | FK → assets.id |
| vulnerability_id | int8 | 是 | 漏洞 ID | FK → vulnerabilities.id |
| created_at | timestamptz | 是 | 建立時間 | Default: now() |
| cvss_score | float8 | 是 | CVSS 漏洞評分 | |
| company_id | int8 | 是 | 所屬公司 ID | FK → companies.id |
| impact_score | float8 | 是 | 影響程度分數 | |
| likelihood_score | float8 | 是 | 發生可能性分數 | |
| risk_level | text | 是 | 風險等級 | |
| treatment_note | text | 是 | 風險處理說明 | |
| treatment_due_date | date | 是 | 風險處理期限 | |
| evidence_url | text | 是 | 佐證資料網址 | |

表 8-2-9 roles (角色表) 欄位定義

| 欄位名稱 | 欄位型態 | 是否可空 | 描述 | 備註 |
|---|---|---|---|---|
| id | uuid | 否 | 角色唯一識別碼 | Primary / Identity |
| role_name | text | 否 | 系統角色名稱（如一般使用者 資安管理員／高階主管 系統管理員） | Unique |
| description | text | 否 | 角色權限或職責說明 | |

表 8-2-10 users (使用者表) 欄位定義

| 欄位名稱 | 欄位型態 | 是否可空 | 描述 | 備註 |
|---|---|---|---|---|
| id | uuid | 否 | 使用者唯一識別碼 | Primary / Identity |
| username | text | 否 | 使用者名稱 | Unique |
| email | text | 是 | 電子郵件 | Unique |
| role_id | uuid | 是 | 角色 ID | FK → roles.id |
| created_at | timestamptz | 是 | 建立時間 | Default: now() |
| company_id | int8 | 是 | 所屬公司 ID | FK → companies.id |
| is_active | bool | 否 | 是否啟用 | |

表 8-2-11 vulnerabilities (弱點表) 欄位定義

| 欄位名稱 | 欄位型態 | 是否可空 | 描述 | 備註 |
|---|---|---|---|---|
| id | int8 | 否 | 弱點唯一識別碼 | Primary / Identity |
| cve_id | text | 是 | CVE 編號 | Unique |
| cvss_score | numeric | 是 | CVSS 風險分數 | |
| severity | text | 是 | 嚴重程度 | |
| description | text | 是 | 弱點描述 | |
| published_date | date | 是 | 發布日期 | |
| created_at | timestamp | 是 | 建立時間 | Default: now() |

表 8-2-12 weight_settings (風險權重設定資料表) 欄位定義

| 欄位名稱 | 欄位型態 | 是否可空 | 描述 | 備註 |
|---|---|---|---|---|
| id | int8 | 否 | 權重設定唯一識別碼 | Primary / Identity |
| company_id | int8 | 否 | 所屬公司識別碼 | FK → companies.id |
| formula_type | text | 否 | 風險計算公式類型 | |
| weight_c | numeric | 否 | 機密性（C）權重比例 | |
| weight_i | numeric | 否 | 完整性（I）權重比例 | |
| weight_a | numeric | 否 | 可用性（A）權重比例 | |
| created_at | timestamptz | 是 | 資料建立時間 | Default: now() |
| updated_at | timestamptz | 是 | 資料最後更新時間 | |

# 第 9 章 程式

## 9-1 元件清單及其規格描述

表 9-1-1 前端程式清單

| 編號 | 檔案名稱 | 功能名稱 |
|---|---|---|
| 1 | _components.html | 共用元件模板 |
| 2 | admin_users.html | 管理員帳號管理介面 |
| 3 | ai_advice.html | AI 資安改善建議介面 |
| 4 | asset_add.html | 資訊資產新增介面 |
| 5 | asset_delete.html | 資訊資產刪除介面 |
| 6 | asset_edit.html | 資訊資產編輯介面 |
| 7 | asset_inventory_result.html | 資產盤點結果介面 |
| 8 | asset_missing.html | 資產缺漏資料顯示介面 |
| 9 | asset_summary.html | 資產摘要資訊介面 |
| 10 | base.html | 共用頁面基底模板 |
| 11 | index.html | 系統首頁 |
| 12 | login.html | 使用者登入介面 |
| 13 | register.html | 使用者註冊介面 |
| 14 | risk_assessment_result.html | 風險評鑑結果介面 |
| 15 | risk_assessment.html | 風險評鑑操作介面 |
| 16 | risk_report.html | 風險評鑑報告介面 |
| 17 | setting.html | 系統設定介面 |
| 18 | weight_setting.html | 風險評估權重設定介面 |

表 9-1-2 後端程式清單

| 編號 | 檔案名稱 | 功能名稱 |
|---|---|---|
| 1 | admin_service.py | 管理員功能服務 |
| 2 | asset_service.py | 資產管理功能服務 |
| 3 | backup_service.py | 系統資料備份服務 |
| 4 | cve_change_detector.py | CVE 資料異動偵測 |
| 5 | cve_embedding.py | CVE 資料向量化處理 |
| 6 | cve_sync_cli.py | CVE 資料同步指令介面 |
| 7 | cve_sync_lock.py | CVE 資料同步鎖定管理 |
| 8 | cve_sync_service.py | CVE 資料自動同步服務 |
| 9 | import_cve.py | CV 資料匯入處理 |
| 10 | nvd_client.py | NVD API 串接服務 |

| | | |
|---|---|---|
| 11 | rag_service.py | RAG 檢索增強生成服務 |
| 12 | report.py | 報表產生服務 |
| 13 | risk_routes.py | 風險評鑑路由管理 |
| 14 | risk_service.py | 風險管理功能服務 |
| 15 | supabase_client.py | Supabase 資料庫連線服務 |

## 9-2 其他附屬之各種元件

表 9-2-1 相關套件清單

| 套件名稱 | 版本 | 功能說明 |
|---|---|---|
| Python | 3.13 | Python 執行環境 |
| Flask | 3.0.3 | Web 應用程式框架 |
| python-dotenv | 1.2.3 | 環境變數管理 |
| supabase | 2.31.0 | 資料庫連線與資料管理 |
| Requests | 2.34.2 | HTTP 請求處理 |
| pytest | 9.1.1 | Python 測試框架 |
| pandas | 3.0.6 | 資料處理與分析 |
| openpyxl | 3.1.5 | Excel 資料處理 |
| google-genai | 2.24.0 | Gemini 生成式 AI 模型串接 |

表 9-2-2 部分程式碼－asset_service.py

asset_service.py

用途：負責資訊資產資料的存取與管理，提供資產資料查詢、新增、修改、刪除。

```
def get_assets(company_id=None):
    """
    取得資產列表
    """
    supabase = get_supabase_client()
    query = (
        supabase
        .table("assets")
        .select("*")
    )
    if company_id:
        query = query.eq(
            "company_id",
            company_id
        )
```

```
        result = (
            query
            .order("id", desc=True)
            .execute()
        )
        return result.data

def get_asset_by_id(asset_id, company_id=None):
        supabase = get_supabase_client()
        query = (
            supabase
            .table("assets")
            .select("*")
            .eq("id", asset_id)
        )
        if company_id:
            query = query.eq(
                "company_id",
                company_id
            )
        result = query.execute()
        if result.data:
            return result.data[0]
        return None

def create_asset(asset):
        supabase = get_supabase_client()
        result = (
            supabase
            .table("assets")
            .insert(asset)
            .execute()
        )
        return result.data

def update_asset(asset_id, data):
        supabase = get_supabase_client()
        result = (
            supabase
            .table("assets")
```

```
            .update(data)
            .eq("id", asset_id)
            .execute()
        )
        return result.data

def delete_asset(asset_id):
        supabase = get_supabase_client()
        result = (
            supabase
            .table("assets")
            .delete()
            .eq("id", asset_id)
            .execute()
        )
        return result.data

def check_asset_code_exists(asset_code):
        supabase = get_supabase_client()
        result = (
            supabase
            .table("assets")
            .select("id")
            .eq(
                "asset_id_code",
                asset_code
            )
            .execute()
        )
        return len(result.data) > 0
```

表 9-2-3 部分程式碼－backup_service.py

| backup_service.py |
| --- |
| 用途：負責系統資料備份， |

```
def create_backup_archive(generated_by, company_id, now=None):
        """Query configured tables and return a sanitized in-memory ZIP export."""
        if (
            not isinstance(company_id, int)
            or isinstance(company_id, bool)
            or company_id <= 0
```

```
    ):
        raise MissingCompanyScopeError("A company scope is required.")
    failed_tables = []
    skipped_tables = []
    exported_tables = {}
    try:
        client = get_supabase_admin_client()
    except Exception as exc:
        error_type = _safe_error_type(exc)
        failed_tables = [
            {"table": table_name, "error_type": error_type}
            for table_name in BACKUP_TABLES
        ]
        raise BackupUnavailableError(failed_tables) from exc
    for table_name in BACKUP_TABLES:
        try:
            exported_tables[table_name] = _query_table(
                client,
                table_name,
                company_id,
                exported_tables,
            )
        except TableScopeSkipped as exc:
            skipped_tables.append(
                {
                    "table": table_name,
                    "reason": exc.reason,
                }
            )
        except Exception as exc:
            error_type = _safe_error_type(exc)
            logger.warning(
                "Backup query failed for table %s (%s).",
                table_name,
                error_type,
            )
            failed_tables.append(
                {
                    "table": table_name,
                    "error_type": error_type,
```

```
                    }
                )
        if not exported_tables:
            raise BackupUnavailableError(failed_tables, skipped_tables)
        generated_at = _utc_now(now)
        included_tables = list(exported_tables)
        manifest = {
            "backup_version": BACKUP_VERSION,
            "generated_at": generated_at.isoformat().replace("+00:00", "Z"),
            "generated_by": generated_by,
            "company_id": company_id,
            "included_tables": included_tables,
            "record_counts": {
                table_name: len(exported_tables[table_name])
                for table_name in included_tables
            },
            "failed_tables": failed_tables,
            "skipped_tables": skipped_tables,
        }
        archive = io.BytesIO()
        with zipfile.ZipFile(archive, mode="w", compression=zipfile.ZIP_DEFLATED) as backup:
            backup.writestr("backup_manifest.json", _json_bytes(manifest))
            for table_name in included_tables:
                backup.writestr(
                    f"{table_name}.json",
                    _json_bytes(exported_tables[table_name]),
                )
        archive.seek(0)
        filename_timestamp = generated_at.strftime("%Y%m%dT%H%M%SZ")
        return {
            "stream": archive,
            "filename": f"riskgenie_backup_{filename_timestamp}.zip",
            "manifest": manifest,
        }
```

表 9-2-4 部分程式碼－rag_service.py

| rag_service.py |
| --- |
| 用途：負責 AI 資安風險分析與改善建議生成，整合資訊資產資料、風險評鑑結果及 RAG 檢索到的 CVE 漏洞資訊，建立提示詞並交由 AI 產生風險分析、可能影響、相關 ISO 27002:2022 控制措施及具體改善建議， |

```
def generate_advice(
    asset_name,
    asset_type="",
    description="",
    threat_description="",
    confidentiality=0,
    integrity=0,
    availability=0,
    legality=0,
    cvss_score=0,
    likelihood_score=0,
    impact_score=0,
    risk_score=0,
    risk_level=""
):
    logger.info(
        "開始產生 AI 建議：%s",
        asset_name
    )

    # 1. 整理資產資訊
    threat_description = (
        threat_description.strip()
        if isinstance(threat_description, str)
        else ""
    )

    description = (
        description.strip()
        if isinstance(description, str)
        else ""
    )

    asset_type = (
        asset_type.strip()
        if isinstance(asset_type, str)
        else ""
    )

    # 如果前端傳 "-"，視為沒有資料
```

```
        if threat_description in ["-", "無", "無資料", "None", "null"]:
            threat_description = ""

        if description in ["-", "無", "無資料", "None", "null"]:
            description = ""

        # 2. 建立 RAG Query
        rag_query = f"""
資產名稱：{asset_name}
資產類型：{asset_type}
資產描述：{description}
目前威脅與弱點：{threat_description}
"""

        logger.info(
            "RAG Query：%s",
            rag_query
        )

        # 3. 搜尋 CVE
        cves = search_cve(
            rag_query,
            match_count=10,
            similarity_threshold=0.70
        )

        # 4. 建立 RAG Context
        context = build_cve_context(cves)

        # 5. 建立完整 Prompt
        prompt = f"""
你是一名企業資安風險評鑑 AI 顧問。

你的工作是根據「實際提供的資產資料」、「風險評鑑結果」
以及「RAG 檢索到的 CVE 資料」，產生專業且可執行的資安改善建議。

==================================================
【一、資產資訊】
==================================================
```

資產名稱：
{asset_name}

資產類型：
{asset_type}

資產描述：
{description if description else "未提供"}

威脅與弱點：
{threat_description if threat_description else "未提供"}

==========
【二、風險評鑑結果】
==========

機密性 C：
{confidentiality}

完整性 I：
{integrity}

可用性 A：
{availability}

適法性 L：
{legality}

CVSS：
{cvss_score}

發生機率 Likelihood：
{likelihood_score}

Impact Score：
{impact_score}

Risk Score：
{risk_score}

Risk Level：
{risk_level}

==========
【三、RAG CVE 資料】
==========

{context}

==========
【四、非常重要的分析規則】
==========

請嚴格遵守以下規則：

1. CVSS 分數只代表本次風險評鑑所設定的弱點嚴重度，
   不代表一定存在 CVE。

2. 只有 RAG CVE 資料中實際出現的 CVE，
   才可以在回答中提及 CVE 編號。

3. 禁止自行創造、猜測或補充任何 CVE 編號。

4. 如果 RAG 沒有找到明確相關 CVE，
   必須明確寫：
   「目前 RAG 知識庫沒有找到與此資產直接相關的 CVE。」

5. 不可以因為 CVSS = 7.5、9.8 等高分，
   就直接宣稱目前資產存在某個漏洞。

6. RAG 搜尋結果的「相似度」只能作為候選資料，
   不代表該 CVE 與資產直接相關。

7. 判斷 CVE 是否直接相關時，
   必須優先確認：
   - 產品名稱
   - 軟體名稱
   - 軟體版本
   - 技術元件
   - 部署環境

8. 如果 RAG 找到 CVE，
但無法確認產品、版本或技術元件與本資產一致，
不得宣稱該 CVE 是本資產目前存在的漏洞。

9. 如果只能確認語意相似，
請說明：
「RAG 找到相似漏洞資訊，但目前無法確認與本資產直接相關。」

10. 如果資產沒有提供產品名稱或版本，
不得自行猜測資產使用的資料庫、Web Server、
作業系統或其他軟體。

11. 如果威脅與弱點沒有提供，
不可以自行假設：
- 未修補
- 權限過大
- 加密不足
- MFA 未啟用
- 防火牆未設定

12. 如果沒有直接相關 CVE，
必須明確說明目前 RAG 知識庫沒有找到直接相關 CVE。

此時可以提出：
- 確認資產所使用的軟體名稱與版本
- 確認作業系統與部署環境
- 執行版本型弱點掃描
- 比對 NVD/CVE 資訊
- 確認高風險漏洞修補狀態

但禁止宣稱資產目前一定存在某個漏洞。

13. 如果涉及法律或合規風險，
未提供具體法規名稱時，
不得自行指定 GDPR 或其他特定法規。
應使用「適用之個人資料保護及相關法規」等描述。

14. 不得宣稱某項資安措施一定可以降低法律責任。
應描述其對降低資訊外洩風險、

事件影響或營運衝擊的作用。

15. Risk Score 與 Risk Level 已由 RiskGenie
Risk Engine 計算完成，
不得自行重新計算 Risk Score，
不得自行修改 Risk Level。

16. AI 的工作是「解釋風險結果」與「提供改善建議」，
而不是取代 Risk Engine。

17. CIA 與 L 分數必須依照提供的評鑑結果分析。

18. 改善建議必須與資產描述、CIA、L、CVSS、
Likelihood、Risk Score 及已知威脅相關。

19. 不要只提供一般性的資安口號。

20. ISO 27002 控制措施只能列出與目前風險相關的措施，
不需要為了湊數量而列出無關控制措施。

21. 如果沒有直接 CVE，
可以提出：
- 確認資產實際使用的軟體與版本
- 執行版本型弱點掃描
- 確認修補狀態
- 檢查存取控制
- 檢查加密措施
等建議。

22. 所有內容使用繁體中文。

==========

【五、分析要求】

==========

請完成：

1. 說明目前主要風險。

2. 解釋為什麼目前 RiskGenie 判定為

「{risk_level}」。

3. 分析 CIA 與適法性的重要性。

4. 說明 RAG 是否找到直接相關 CVE。

5. 如果有相關 CVE：
   - 列出 CVE ID
   - 說明與資產的關聯
   - 說明漏洞可能造成的影響

6. 如果沒有相關 CVE：
   明確說明沒有找到直接相關 CVE，
   不得自行補充 CVE。

7. 提出具體改善措施。

8. 每一項改善措施說明：
   - 建議做什麼
   - 為什麼
   - 建議優先程度

9. 提供相關 ISO 27002:2022 控制措施。

10. 最後提出最優先處理事項。

==========
【六、輸出格式】
==========

請嚴格按照以下格式回答：

【風險分析】

說明目前主要資安風險，
並結合資產描述、CIA、L、CVSS、
Likelihood、Risk Score 與 Risk Level。

【可能影響】

列出可能造成的：
1. 資料影響
2. 營運影響
3. 法律 / 合規影響
4. 財務或聲譽影響

【相關漏洞 / CVE】

如果 RAG 有找到直接相關 CVE：

CVE-XXXX-XXXXX
- 漏洞說明：
- 與本資產的關聯：
- 可能影響：

如果沒有：

目前 RAG 知識庫沒有找到與此資產直接相關的 CVE。
建議確認資產實際使用的軟體、版本與部署環境，
再進一步進行版本型弱點掃描。

【ISO 27002:2022 控制措施】

請列出最相關的 2～4 項控制措施，
並說明每項措施與目前風險的關聯。

【改善建議】

請依照目前 Risk Score、Risk Level、CIA/L、
CVSS、Likelihood 以及 RAG 檢索結果，
提出 3 項最具體且可執行的改善措施。

請依重要性排序，格式如下：

1. 【最高優先】
   措施：
   原因：

2. 【高優先】
   措施：

```
    原因：

3. 【中優先】
    措施：
    原因：

每項措施都必須：
- 與目前資產及風險直接相關
- 說明具體應執行的工作
- 說明為什麼需要處理
- 不得重複前面的建議

【風險降低重點】

請用 2～3 句話總結目前最重要的風險降低方向，
不要重新列出前三項改善措施。
"""
```

表 9-2-5 部分程式碼－risk_service.py

risk_service.py

用途：負責資訊安全風險評鑑權重與公式設定的讀取、儲存及管理，支援依公司 ID 取得設定、建立預設值、更新權重與評鑑公式，

```
class RiskService:
    @staticmethod
    def get_weight_settings(company_id: int) -> dict:
        """
        根據公司 ID 讀取權重與公式設定。
        """
        company_id = validate_company_id(company_id)
        default_settings = {
            "company_id": company_id,
            "formula_type": "max",
            "weight_c": 0.3333,
            "weight_i": 0.3333,
            "weight_a": 0.3333
        }

        try:
            supabase = get_supabase_client()
            response = supabase.table("weight_settings").select("*").eq("company_id",
```

```
company_id).execute()

            if response.data and len(response.data) > 0:
                data = response.data[0]
                return {
                    "company_id": int(data.get("company_id", company_id)),
                    "formula_type": normalize_formula_type(data.get("formula_type", "max")),
                    "weight_c": float(data.get("weight_c", 0.3333)),
                    "weight_i": float(data.get("weight_i", 0.3333)),
                    "weight_a": float(data.get("weight_a", 0.3333))
                }
            else:
                # 主動建立一筆預設值
                try:
                    insert_data = {
                        "company_id": company_id,
                        "formula_type": "max",
                        "weight_c": 0.3333,
                        "weight_i": 0.3333,
                        "weight_a": 0.3333,
                        "created_at": datetime.utcnow().isoformat(),
                        "updated_at": datetime.utcnow().isoformat()
                    }
                    supabase.table("weight_settings").insert(insert_data).execute()
                except Exception as ins_err:
                    logger.warning(f"無法在資料庫建立預設權重設定: {ins_err}")
                return default_settings

        except Exception:
            logger.exception("Supabase 查詢 weight_settings 失敗，啟用降級機制。")

            try:
                fallback_data = load_fallback_settings()
                company_key = str(company_id)
                if company_key in fallback_data:
                    settings = fallback_data[company_key]
                    settings["formula_type"] = normalize_formula_type(
                        settings.get("formula_type", "max")
                    )
                    return settings
```

```
                except Exception:
                    logger.exception("讀取本地權重備份檔失敗。")

                return default_settings

    @staticmethod
    def save_weight_settings(company_id: int, formula_type: str, weight_c: float, weight_i: float,
weight_a: float) -> dict:
        """
        儲存或更新給定公司 ID 的權重公式設定（使用 Supabase Upsert 確保寫入成功）。
        """
        company_id = validate_company_id(company_id)
        weight_c = float(weight_c)
        weight_i = float(weight_i)
        weight_a = float(weight_a)
        formula_type = normalize_formula_type(formula_type)

        settings_dict = {
            "company_id": company_id,
            "formula_type": formula_type,
            "weight_c": weight_c,
            "weight_i": weight_i,
            "weight_a": weight_a
        }

        supabase_success = False
        local_backup_success = False

        # 1. 寫入雲端 Supabase 資料庫
        try:
            supabase = get_supabase_client()
            now_str = datetime.utcnow().isoformat()

            # 查詢該公司是否已有紀錄
            check_res = supabase.table("weight_settings").select("id").eq("company_id",
company_id).execute()

            if check_res.data and len(check_res.data) > 0:
                record_id = check_res.data[0]["id"]
                # UPDATE 既有紀錄
```

```
                update_res = supabase.table("weight_settings").update({
                    "formula_type": formula_type,
                    "weight_c": weight_c,
                    "weight_i": weight_i,
                    "weight_a": weight_a,
                    "updated_at": now_str
                }).eq("id", record_id).execute()
                logger.debug("Supabase weight_settings update completed.")
            else:
                # INSERT 新紀錄
                insert_res = supabase.table("weight_settings").insert({
                    "company_id": company_id,
                    "formula_type": formula_type,
                    "weight_c": weight_c,
                    "weight_i": weight_i,
                    "weight_a": weight_a,
                    "created_at": now_str,
                    "updated_at": now_str
                }).execute()
                logger.debug("Supabase weight_settings insert completed.")

            supabase_success = True
            logger.info(f"公司 {company_id} 權重設定已成功儲存至 Supabase。")
        except Exception as e:
            logger.error(
                "無法儲存權重設定到 Supabase: %s",
                type(e).__name__,
            )

        # 2. 同步寫入本地 JSON 備份檔
        try:
            os.makedirs(os.path.dirname(FALLBACK_FILE), exist_ok=True)
            try:
                fallback_data = load_fallback_settings()
            except Exception:
                fallback_data = {}

            fallback_data[str(company_id)] = settings_dict
            with open(FALLBACK_FILE, "w", encoding="utf-8") as f:
                json.dump(fallback_data, f, ensure_ascii=False, indent=4)
```

```
            local_backup_success = True
        except Exception as json_err:
            logger.error(
                "無法將權重設定寫入本地備份檔: %s",
                type(json_err).__name__,
            )

        success = supabase_success or local_backup_success
        if supabase_success and local_backup_success:
            status = "synced"
            message = "權重與公式設定儲存成功。"
        elif supabase_success:
            status = "cloud_only"
            message = "已儲存至雲端，但本機備份寫入失敗。"
        elif local_backup_success:
            status = "local_backup_only"
            message = "已儲存至本機備份，但雲端同步失敗。"
        else:
            status = "failed"
            message = "權重設定儲存失敗。"

        return {
            "success": success,
            "supabase_synced": supabase_success,
            "local_backup_saved": local_backup_success,
            "status": status,
            "message": message,
            "settings": settings_dict
        }
```

# 第 10 章 測試模型

## 10-1 測試計畫

- 測試平台：使用 RiskGenie 評評理進行功能測試，並針對不同瀏覽器環境進行相容性測試，以確認系統介面及功能是否正常運作。
- 測試方式：針對系統各功能模組進行單元測試、整合測試及功能測試，透過模擬使用者操作流程，檢查各項功能是否能正常執行，以及不同模組間的資料傳遞是否正確。
- 測試目標：驗證系統功能的正確性、穩定性及易用性，確認各項功能符合系統需求，並確保使用者能順利完成相關操作。
- 主要測試如下：

表 10-1-1 測試項目表 [序號 5]

| 項目 | 測試目的 |
| --- | --- |
| 功能測試 | 測試使用者登入、資訊資產新增、查詢、修改及刪除、資產盤點與缺漏提示、AI 輔助 CIA 價值評定、風險評鑑、CVE 漏洞資訊整合、AI 資安改善建議、權重設定及帳號權限管理等功能，確認各項操作結果符合預期。 |
| 使用者介面測試 | 確認系統介面的顯示及操作是否正常，包含不同瀏覽器的介面相容性、資產列表呈現、風險矩陣圖表顯示，以及表單驗證與錯誤提示等功能。 |
| 管理者介面測試 | 驗證管理者相關功能的存取權限，確認不同角色的使用者只能執 |

| | |
|---|---|
| | 行其權限允許的操作，並檢查帳號狀態及權限設定是否正確。 |
| 資料庫測試 | 驗證 Supabase（PostgreSQL）資料庫的資料新增、查詢、修改及刪除功能，並確認資料儲存與關聯性符合系統設計。 |
| 效能與外部整合測試 | 測試系統與 NVD/CVE 漏洞資訊來源、Google Gemini API 及相關檢索機制的整合情形，確認外部服務正常時，系統能依預期取得資料並回傳處理結果。 |

## 10-2 測試個案與測試結果資料

表 10-2-1 登入功能測試結果

| | |
|---|---|
| 功能名稱 | 使用者登入 |
| 測試說明 | 測試使用者登入功能，輸入正確帳號與密碼後登入 |
| 預測結果 | 登入成功，跳轉至首頁 |
| 測試結果 | 通過 |

表 10-2-2 資訊資產 CRUD 功能測試結果

| | |
|---|---|
| 功能名稱 | 資訊資產新增、刪除、修改、查詢 |
| 測試說明 | 登入系統後，對資產清冊執行新增、刪除、修改及查詢動作 |
| 預測結果 | 各項 CRUD 操作皆能正確與資料庫互動，前端即時反饋成功訊息，無關聯評鑑之資產可順利刪除 |
| 測試結果 | 通過 |

表 10-2-3 資產盤點功能測試結果

| | |
|---|---|
| 功能名稱 | 資產盤點 |
| 測試說明 | 執行資產盤點完整性檢查，驗證系統對必要欄位缺漏的偵測與前端提示機制 |
| 預測結果 | 若資料有缺漏，前端能即時彈出缺漏提示；資料完整則順利顯示完整的盤點清單 |
| 測試結果 | 通過 |

表 10-2-4 風險評鑑功能測試結果

| 功能名稱 | 風險評鑑 |
| --- | --- |
| 測試說明 | 選定資產執行風險評鑑，系統自動對應 CVE 漏洞資料庫之 CVSS 分數，依公式計算風險值 |
| 預測結果 | 系統正確計算出風險分數與對應之風險等級，並將評鑑結果寫入資料庫 |
| 測試結果 | 通過 |

表 10-2-5 風險評鑑 AI 建議功能測試結果

| 功能名稱 | 風險評鑑 AI 建議 |
| --- | --- |
| 測試說明 | 針對已完成評鑑之中高風險資產，點擊查看 AI 改善建議 |
| 預測結果 | 從資料庫中搜索相關資訊，順利產出具備條文依據之白話風險處理計畫 |
| 測試結果 | 通過 |

表 10-2-6 權重設定功能測試結果

| 功能名稱 | 權重設定 |
| --- | --- |
| 測試說明 | 進入權重設定模組，調整 CIA 權重參數或計算公式類型 |
| 預測結果 | 設定值能成功儲存至資料庫，後台重新執行風險評鑑時，能依據新權重正確重新計算風險分數 |
| 測試結果 | 通過 |

表 10-2-7 帳號與權限管理測試結果

| 功能名稱 | 帳號與權限管理 |
| --- | --- |
| 測試說明 | 測試管理者登入後，對系統使用者帳號進行新增、修改、停用或權限設定 |
| 預測結果 | 帳號狀態與權限能即時更新至資料庫，且受影響帳號再次登入時會受到對應權限限制 |
| 測試結果 | 通過 |

表 10-2-8 系統資料備份測試結果

| 功能名稱 | 系統資料備份 |
| --- | --- |
| 測試說明 | 系統管理員於後台手動執行或觸發系統資料庫備份作業 |
| 預測結果 | 系統順利執行備份程序，降低資料遺失風險並留下對應操作紀錄 |
| 測試結果 | 通過 |

# 第 11 章 操作手冊

## 11-1 系統需求

- 網頁瀏覽器：支援 Google Chrome、Mozilla Firefox、Safari 或 Microsoft Edge。
- 網路連線：需具備穩定的網路連線，以確保系統功能及相關服務正常運作。
- 作業系統：Windows 10 以上或 macOS Sonoma 以上版本。

表 11-1-1 系統安裝元件與環境設定

| 項目 | 內容 |
|---|---|
| 系統名稱 | RiskGenie 評評理 |
| 系統版本 | 1.0 |
| 支援語言 | 繁體中文 |
| 網頁應用框架 | Flask 3.0.3 |
| 使用者驗證套件 | Flask-Login 0.6.3 |
| 部署相關套件 | Waitress 3.0.0 |
| 資料庫服務 | Supabase（PostgreSQL） |
| 系統部署平台 | Render |
| 系統存取方式 | 透過網頁瀏覽器連線使用 |

表 11-1-2 系統管理功能

| 功能 | 說明 |
|---|---|
| 使用者管理 | 管理員可依系統權限新增、修改及刪除使用者帳戶資訊。 |
| 資產管理 | 使用者可依系統提供的功能，新增、查詢、修改及刪除資訊資產資料。 |
| 資料備份 | 依資料庫服務及部署環境的設定進行資料備份；如已配置相應機制，則可執行資料還原。 |

## 11-2 系統連線與操作方式

開啟網頁瀏覽器，在網址列輸入以下網址，並按下 Enter 鍵，即可進入 RiskGenie 評評理的登入畫面。系統網址：https://risk-assessment-project-m459.onrender.com

- 登入與系統操作：

1. 使用者登入：進入登入畫面後，依照頁面提示輸入帳號及密碼。

2. 進入系統：登入成功後，系統依使用者角色及權限導向相應頁面。

3. 執行系統功能：使用者可依需求進行資訊資產管理、風險評鑑、CVE 漏洞資訊查詢及 AI 資安改善建議等操作。

4. 管理員操作：具備管理員權限的使用者，可進一步執行使用者管理及其他授權的管理功能。

# 第 12 章 使用手冊

表 12-1-1 登入作業

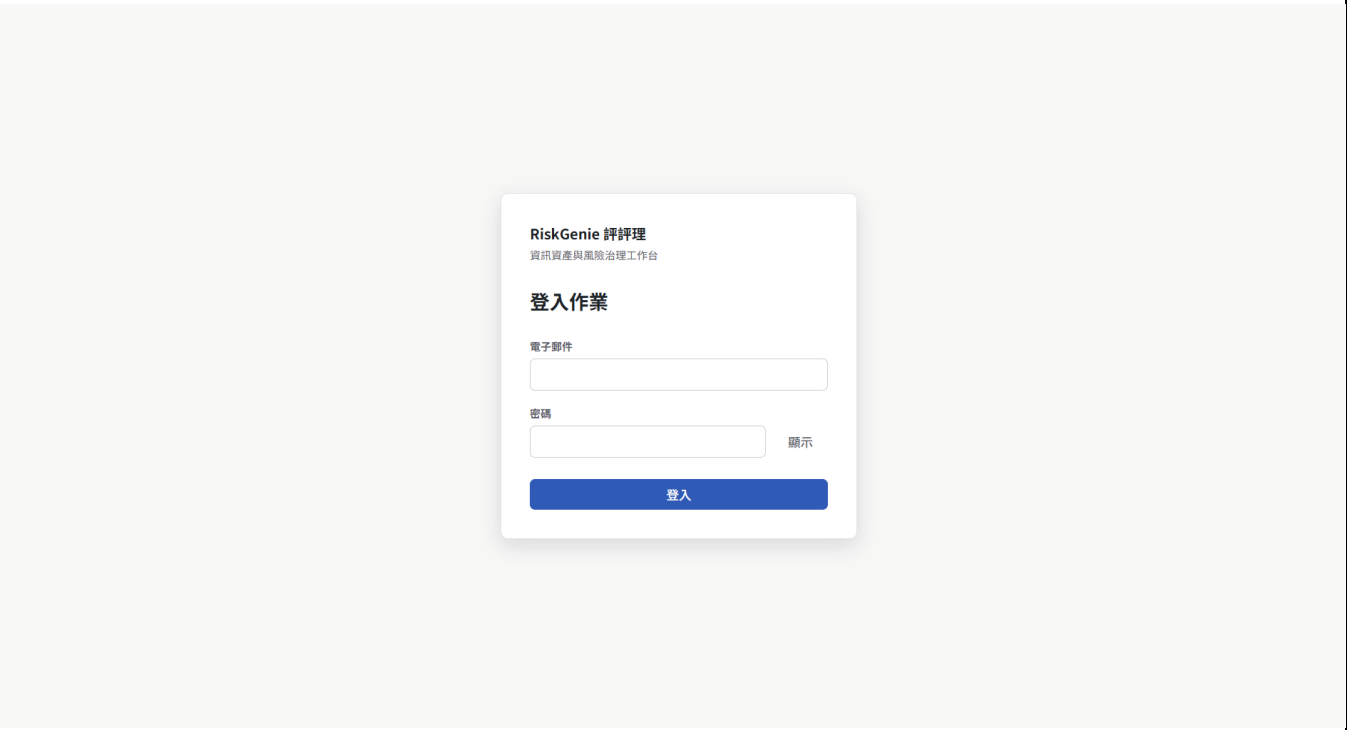
| 進入 RiskGenie 的登入介面 |
| --- |
|  |



表 12-1-2 主畫面

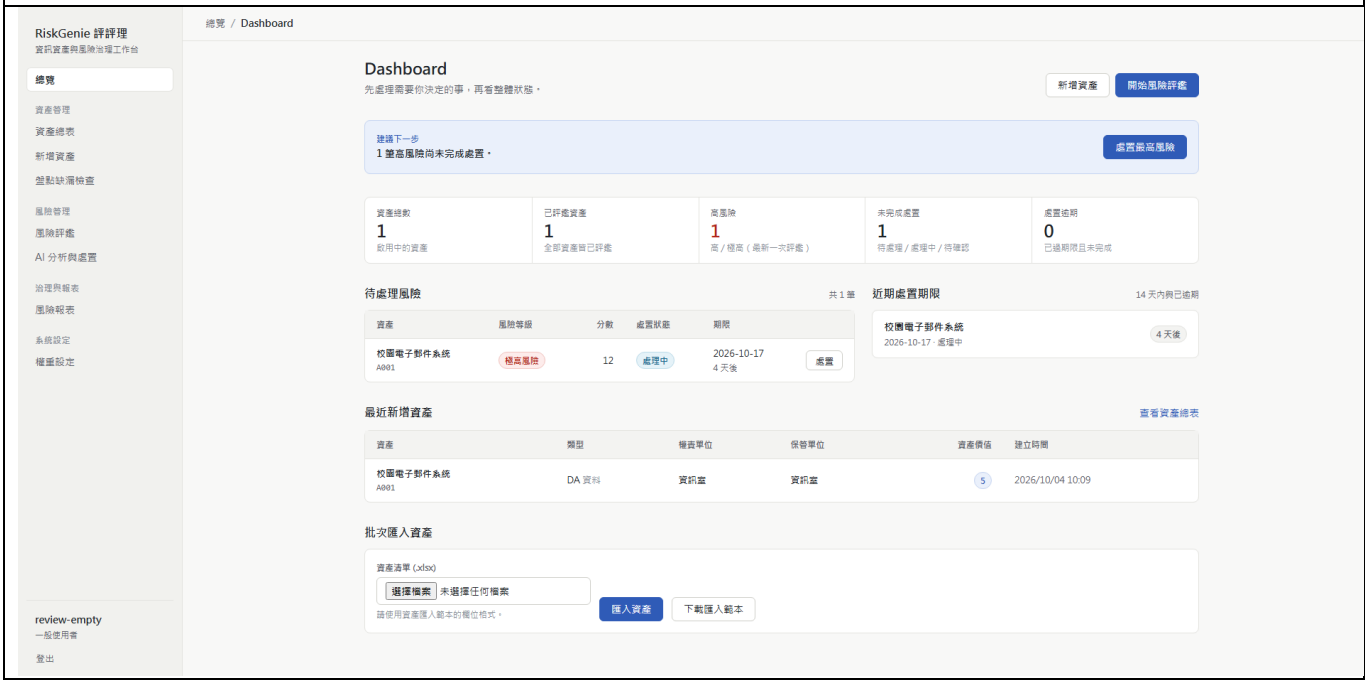
| 主畫面 |
| --- |
|  |

表 12-1-3 資產總表

資產總表

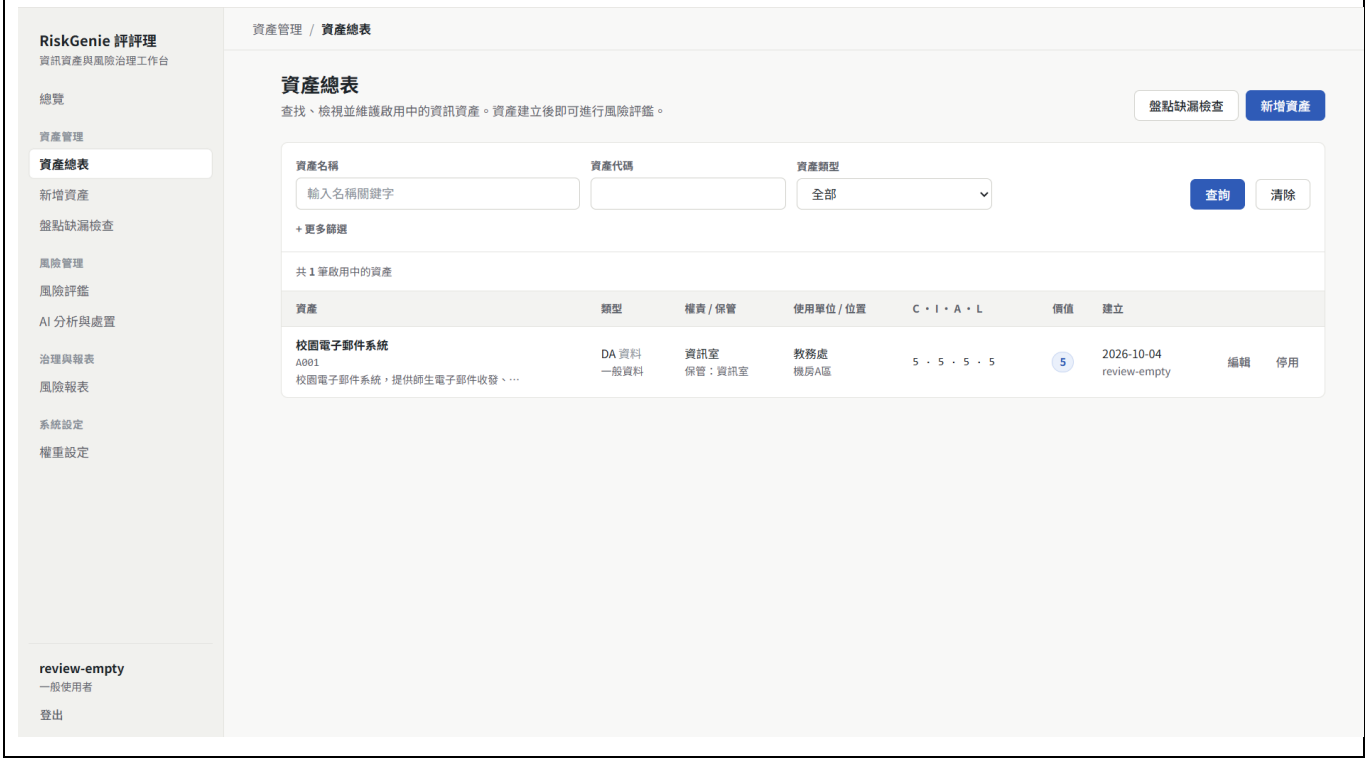



表 12-1-4 資產盤點

資產盤點



表 12-1-5 風險評鑑

| 風險評鑑 |
| --- |
|  |



表 12-1-6 風險評鑑 AI 建議

| 風險評鑑 AI 建議 |
| --- |
|  |

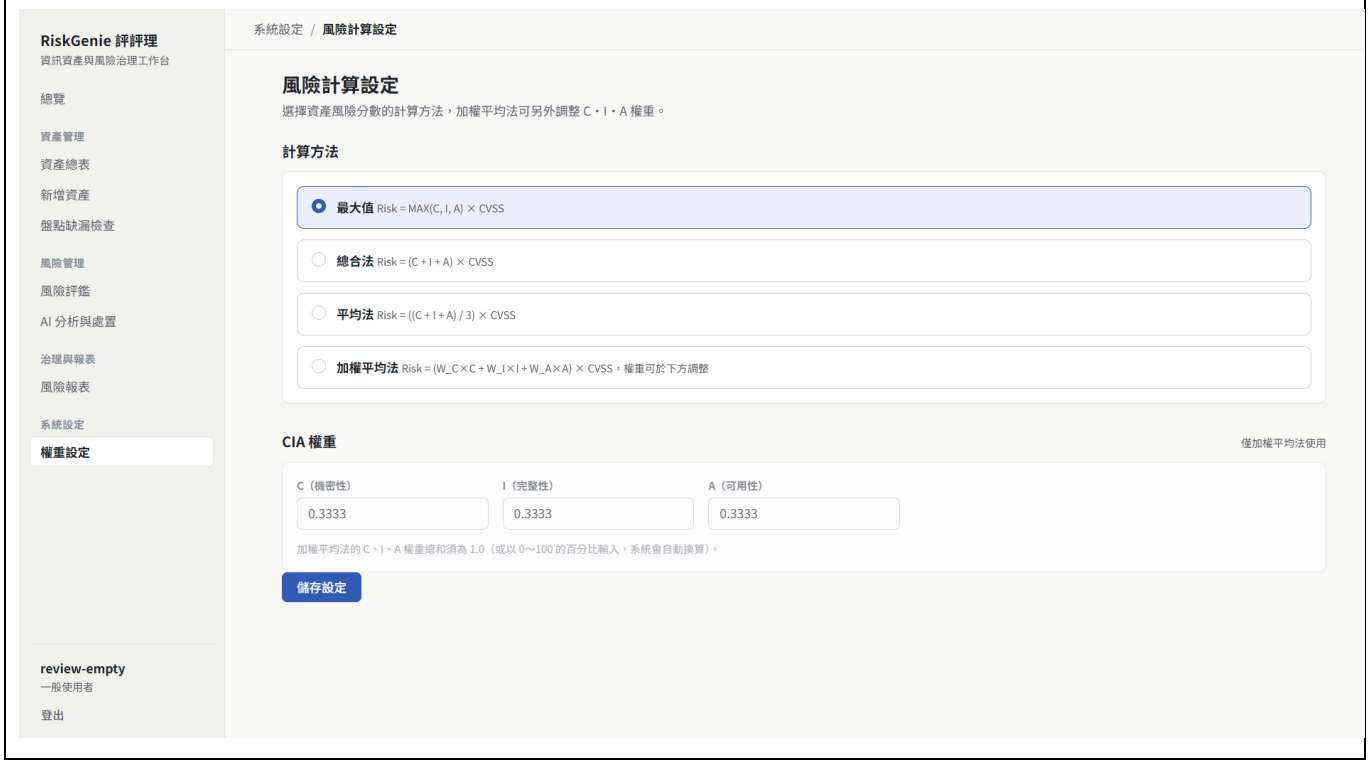
## 12-1-7 風險報表

風險報表




## 表 12-1-8 權重設定

權重設定



# 第 13 章 感想

- 11436008 林紀媗

在這次專題中，我學習到資訊安全風險評鑑不只是填寫資料與計算分數，更需要全面考量資產的重要性、潛在威脅及後續的改善措施。從前期的系統規劃、資料庫設計，到後期的功能整合與測試，過程中雖然遇到不少挑戰，但也讓我深刻體會到團隊溝通與分工合作的重要性。

在開發過程中，我了解到 AI 能為資訊安全工作帶來新的可能性，協助分析風險與提供改善建議，讓原本繁瑣的評鑑流程更加有效率。雖然 AI 的分析仍有其限制，但善用 AI 的輔助能力，能更快速地掌握風險狀況與改善方向。這次專題不僅加深了我對資訊安全與系統開發的認識，也讓我將課堂所學實際應用於系統設計與開發中，累積了解決問題與團隊合作的寶貴經驗。

- 11436010 李昕縈

在專題中，我負責將風險評鑑結果與相關的 CVE 弱點資料整合，再透過 RAG 技術，將整合後的資訊提供給生成式 AI 作為分析依據，產生相應的資安改善建議。由於過去較少接觸資訊安全相關領域，因此在專題初期，我先學習資訊資產盤點及風險評鑑的基本流程，了解如何辨識與整理資訊資產，並依據資產的重要性及潛在威脅進行風險分析。在整合 AI 功能的過程中，我也逐漸了解 RAG 技術的應用方式，並學會主動查找資料、理解技術原理，將所學應用於系統開發中，培養自主學習與解決問題的能力。最後，透過團隊分工與合作，我們順利完成專題，也累積了實務經驗。

- 11436017 顏珮倪

這次參與 RiskGenie 的開發，讓我印象最深刻的是系統整合與對外參賽的過程。雖然過去已有專案開發經驗，但這次除了處理 GitHub 版本整合、功能測試，也需要花不少時間整理競賽文件與論文。由於大家負責的功能不同，對系統的理解難免有些落差，因此在統整資料時，經常需要重新確認實作內容並調整論述，過程比預期繁瑣，但也讓我更熟悉整套系統。

另外，從 AI 輔助 CIA 評值的實作到後續實驗，讓我開始更仔細地思考系統設計的合理性，不只是功能能否正常運作。

很感謝組員們願意配合各階段的調整，也各自投入心力完成負責的部分。能夠一起把作品逐步完善，甚至嘗試投稿競賽與論文，對我來說是這次專題很有意義的收穫。

- 11436021 黃翊甄

在這次專題開發中，我主要負責前端介面與 UI/UX 設計。這是我第一次實際接觸資安領域，剛開始面對繁複的資安規範與風險名詞時，確實充滿了挑戰。如何將生硬的資安概念與 AI 顧問功能，轉化為直覺好操作的網頁介面，是我這次專題製作中的核心目標。從資產盤點表單、缺漏欄位的即時互動提示，到風險評鑑結果與 AI 改善建議的視覺化排版，透過與團隊夥伴的合作，順利完成 API 串接與前端優化。這次的專題不僅大幅提升了我的介面設計與實作能力，也讓我對資訊安全領域有更深的了解，為專題留下扎實的成果。

- 11436029 林敬芬

剛開始時，我們幾乎是從零開始認識資訊安全這方面的知識，面對很多的規範與專有名詞，只覺得內容既抽象又陌生。後來透過反覆閱讀、討論，再一步步把概念落實到系統設計裡，才慢慢理解這些要求背後的意義。這段過程讓我體會團隊合作的重要性，每個人負責的部分不同，唯有不斷溝通，才能把各自的成果整合成一個完整的系統。另外，基本的資安知識是根基，沒有扎實的理解，就無法判斷系統做得對不對。最重要的是也從這次專題之中了解 AI 並不是萬能的，它有時會講出看似合理卻不正確的內容，所以我們花了不少心力去檢查與修正，讓它的建議更可靠。這次專題不只讓我學到新知識，也讓我學會面對陌生領域時，如何一步步找到方向。

# 第 14 章 參考資料

※使用人工智慧或生成式人工智慧做為輔助作品產出工具之說明：

□未使用人工智慧科技做為輔助作品產出之工具（以下免填）

☑使用人工智慧科技做為輔助作品產出之工具（請填下表，表格不足請自行增列）

| 序號 | 使用工具名稱 | 使用範圍及說明 | 頁碼 |
|---|---|---|---|
| 1 | Gemini | 背景介紹及預期成果內容修飾 | 1、3 |
| 2 | ChatGPT | 成本結構及收益流內容建議 | 7 |
| 3 | ChatGPT | 開發工具與技術說明內容修飾 | 15-17 |
| 4 | Claude | 需求說明內容修飾 | 22-23 |
| 5 | ChatGPT | 測試項目表內容修飾 | 76 |

其他參考資料：

E 等公務園

(1) ISMS 認證流程導覽

(2) ISO 27001 控制措施與資通系統防護基驗證實務

(3)資通系統盤點及安全等級評估

IS Capt. AI 智慧資安管理平台-系統手冊.pdf

動起來「揪」對了-系統手冊.pdf

檢索增強生成與微調大語言模型於資安管理應用之研究.pdf

# 附錄

| 評審建議事項 | 修正情形 |
| --- | --- |
| 1. 本系統具高度專業性，應積極補強相關知識與法規，並納入系統開發中。另系統文件內容宜檢視正確性與完整性。 | 已修正 |
| 2. 開發之系統應與系統文件一致完整。 | 已修正 |